

The logo consists of a white rounded square with the word "Kesh" in a bold, dark blue sans-serif font centered within it.

Kesh

Documentation technique

Manuel administrateur

Installation, configuration et exploitation de Kesh dans un
environnement de production

Version **0.8.0** | 2026-07-26

Cible release : **v0.8**

<https://github.com/guycorbaz/kesh>

Table des matières

1	À propos de ce manuel	5
1.1	Public cible	5
1.2	Pré-requis de lecture	5
1.3	Conventions typographiques	5
2	Présentation de Kesh	6
2.1	Objectif du logiciel	6
2.2	Public cible du produit	6
2.3	Architecture technique haute	7
2.4	Licence	7
3	Prérequis système	7
3.1	Système d'exploitation	7
3.2	Logiciels requis	7
3.3	Ressources matérielles minimales	8
3.4	Ports réseau	8
3.4.1	Changer le port d'écoute (conflit port 80, ex. Synology DSM Web Station)	9
4	Installation	9
4.1	Méthode recommandée : Docker Compose	9
4.1.1	Étape 1 — Préparer l'environnement	9
4.1.2	Étape 2 — Récupérer le <code>docker-compose.yml</code>	10
4.1.3	Étape 3 — Créer le fichier <code>.env</code>	10
4.1.4	Étape 4 — Démarrer les services	11
4.1.5	Étape 5 — Vérifier l'installation	11
4.2	Configuration du reverse proxy HTTPS	11
4.3	Alternative : déploiement via Caddy	12
4.4	Alternative : déploiement via Traefik (avec firewall applicatif)	13
4.4.1	Compose Traefik en sidecar	13
4.4.2	Middlewares firewall applicatif	14
4.4.3	Plugins WAF avancés (optionnel, recommandé Internet-exposed)	15
4.4.4	Considérations sécurité spécifiques	16
4.5	Alternative : déploiement sur Synology DSM	16
4.5.1	Prérequis Synology DSM	16
4.5.2	Étape 1 — Préparer la structure de répertoires	16
4.5.3	Étape 2 — Récupérer <code>docker-compose.yml</code> et <code>.env</code>	17
4.5.4	Étape 3 — Importer le projet dans Container Manager	17
4.5.5	Étape 4 — Configurer le reverse proxy DSM (Application Portal)	18

4.5.6	Étape 5 — Vérification post-installation	19
4.5.7	Limitations Container Manager DSM	19
5	Configuration	20
5.1	Variables d'environnement complètes	20
5.1.1	Import de factures depuis un dossier	23
5.1.2	Monitoring	24
5.2	Configuration des logs fichier	24
5.3	Configuration MariaDB	25
5.3.1	Paramètres recommandés	25
5.3.2	Initialisation manuelle de la base	26
5.4	Configuration multi-tenant	26
5.4.1	Concept de <i>company</i>	27
5.4.2	Isolation des données	27
5.4.3	Cas d'usage fiduciaire	27
6	Premier démarrage	27
6.1	Création du compte administrateur initial (onboarding self-service)	27
6.1.1	Procédure (nouveau flow recommandé v0.1.2+)	28
6.1.2	Procédure alternative — bootstrap déclaratif via <code>.env</code>	28
6.2	Récupération de mot de passe par email (SMTP)	29
6.2.1	Variables de configuration	29
6.2.2	Exemples de providers	30
6.2.3	Fonctionnement et garanties	30
6.2.4	Test après configuration (recommandé)	31
6.2.5	Limitations connues	31
6.3	Envoi de factures par e-mail	32
6.3.1	Activation	32
6.3.2	Identité d'expédition	32
6.3.3	Garanties et limites	32
6.4	Modèles d'e-mail	33
6.5	Rappels débiteurs (réglages)	33
6.5.1	Niveaux de rappel	33
6.5.2	Période de grâce	34
6.6	J'ai oublié mon mot de passe administrateur (recovery break-glass)	34
6.6.1	Procédure step-by-step	34
6.6.2	Matrice de comportement au boot — vue d'ensemble	35
6.7	Déploiement LAN HTTP-only (sans HTTPS) — v0.1.3+	35
6.7.1	Décision : HTTPS ou HTTP-only ?	36
6.7.2	Procédure HTTP-only (<code>KESH_COOKIE_SECURE=false</code>)	37
6.7.3	Valeurs acceptées et fail-fast	37
6.8	Configuration de la company via l'onboarding	37
6.9	Choix du plan comptable	38

6.10	Configuration des exercices comptables	38
6.11	Création des utilisateurs et rôles	38
7	Sauvegarde et restauration	39
7.1	Importance de la sauvegarde	39
7.2	Stratégie recommandée	39
7.3	Script de sauvegarde mariadb-dump	40
7.4	Stockage offsite	41
7.5	Restauration depuis sauvegarde	41
7.6	Test de restauration périodique (OLiCo Art. 10 al. 1)	41
7.7	Backup natif sur Synology DSM (Hyper Backup + Snapshot Replication)	42
7.7.1	Hyper Backup — backup incrémental + offsite intégré	42
7.7.2	Snapshot Replication — recovery instantané point-in-time	43
7.7.3	Stratégie 3-2-1 sur DSM	44
7.8	Export/import d'installation via l'interface Kesh	45
7.8.1	Exporter (sauvegarde complète)	45
7.8.2	Importer (restauration / migration)	45
7.8.3	Quelle méthode de sauvegarde choisir ?	47
8	Mise à jour de Kesh	48
8.1	Process de release Kesh	48
8.2	Suivre les notifications de release	48
8.3	Procédure de mise à jour standard	48
8.4	Mise à jour majeure (changement de version X)	49
8.5	Rollback en cas d'échec	49
9	Sécurité	49
9.1	HTTPS obligatoire en production	49
9.2	Gestion des secrets	50
9.3	Authentification JWT + refresh tokens	50
9.4	Clés API (PAT) — accès programmatique	50
9.5	RBAC et permissions	51
9.6	Audit-trail (audit_log)	51
9.7	Conformité OLiCo Art. 9 — intégrité des supports modifiables	52
9.8	Sécurité réseau (firewall)	52
9.9	Mises à jour de sécurité du système hôte	52
10	Monitoring et logs	53
10.1	Logs applicatifs	53
10.2	Centralisation des logs	53
10.3	Supervision (état de santé)	53

10.4 Alerting recommandé	54
11 Conformité légale suisse	54
11.1 Code des obligations Art. 957a — Tenue de la comptabilité	54
11.2 Code des obligations Art. 958f — Conservation 10 ans	54
11.3 Rétention des rappels débiteurs (dossier de recouvrement)	55
11.4 Ordonnance OLICo (RS 221.431)	55
11.5 LSCSE (signature électronique qualifiée)	56
11.6 Loi sur la TVA (LTVA)	56
11.7 Documentation à conserver	56
12 Dépannage	57
12.1 Kesh ne démarre pas	57
12.2 Erreurs 401 en cascade côté frontend	57
12.3 Performance lente sur de gros datasets	58
12.4 Reset du mot de passe administrateur (break-glass)	58
12.5 Données corrompues détectées	58
13 Maintenance	59
13.1 Rotation des logs	59
13.2 Maintenance MariaDB	59
13.3 Vérification périodique de l'intégrité (OLICo Art. 10)	60
14 Annexes	60
14.1 Liste complète des variables d'environnement	61
14.2 Opérations en ligne de commande	61
14.3 Référence des ports	61
14.4 Glossaire	61
14.5 Liens externes	62
14.6 Support et communauté	62

1 À propos de ce manuel

Ce manuel s'adresse aux administrateurs système, responsables DevOps et fiduciaires souhaitant déployer et exploiter Kesh dans un environnement de production. Il couvre l'ensemble du cycle de vie opérationnel d'une instance Kesh : installation, configuration, sauvegarde, mise à jour, sécurité, conformité légale suisse et dépannage.

1.1 Public cible

Ce document est rédigé pour :

- Les administrateurs système (Linux ou macOS) responsables de l'hébergement d'une instance Kesh pour une ou plusieurs PME.
- Les fiduciaires souhaitant proposer Kesh comme solution comptable à leurs clients en mode self-hosting.
- Les développeurs internes d'une PME prenant en charge l'auto-hébergement de leur instance.
- Les responsables sécurité ou conformité devant valider la posture Kesh face aux exigences du Code des obligations suisse (CO Art. 957a, 958f) et de l'Ordonnance OLICo (RS 221.431).

1.2 Pré-requis de lecture

Le lecteur est supposé familier avec :

- Les concepts de base de Docker et Docker Compose (images, volumes, networks).
- L'administration d'un système Linux (CLI, systemd, gestion de paquets, permissions de fichiers).
- Les principes d'une base de données relationnelle (MariaDB/MySQL).
- Les concepts de reverse proxy HTTPS (Nginx, Traefik ou équivalent).
- Les notions de base de cryptographie appliquée (TLS, certificats, secrets).

1.3 Conventions typographiques

- `commande shell` : commande à exécuter dans un terminal.
- `/chemin/fichier` : chemin vers un fichier ou répertoire sur le système.
- `Ctrl+S` : combinaison de touches clavier.
- Les boîtes colorées : *Note* (information), *Astuce*, *Attention* (avertissement), *Danger* (risque critique).

i Note

Ce manuel décrit Kesh version 0.8.0. Pour la dernière version, consultez <https://github.com/guycorbaz/kesh>. Voir la section finale « À propos de cette version » pour les modalités de mise à jour.

2 Présentation de Kesh

2.1 Objectif du logiciel

Kesh est un **logiciel de comptabilité et de gestion** destiné aux indépendants, petites et moyennes entreprises (PME) et associations en Suisse. Il fournit un système complet conforme aux exigences du Code des obligations suisse, incluant :

- **Comptabilité en partie double** avec plan comptable suisse PME (Sterchi, KMU, ou personnalisé).
- **Facturation QR Bill 2.2** conforme au standard SIX Interbank Clearing (norme suisse 2020+).
- **Import bancaire** CAMT.053 (ISO 20022) et CSV multi-encodage avec profils banque réutilisables.
- **Réconciliation automatique et manuelle** des transactions bancaires avec règles d'affectation.
- **Rapports comptables** : bilan, compte de résultat, balance, journal.
- **Exports** légaux : PDF par rapport, ZIP global de souveraineté avec SHA-256 d'intégrité.
- **Multi-utilisateurs** avec contrôle d'accès basé sur les rôles (RBAC).
- **Multi-tenant** : isolation stricte des données par société (*company_id*).
- **Multilingue** : interface utilisateur en français, allemand, italien et anglais.

2.2 Public cible du produit

Kesh est conçu pour :

- Les **entreprises individuelles** et les **sociétés de personnes** avec un chiffre d'affaires supérieur à CHF 500'000 (régime « comptabilité complète » selon CO Art. 957 al. 1).
- Les **entreprises individuelles** et **sociétés de personnes** avec un chiffre d'affaires inférieur à CHF 500'000 (régime « recettes-dépenses + patrimoine » selon CO Art. 957 al. 2).
- Les **personnes morales** (SA, Sàrl, coopératives, associations, fondations).
- Les **fiduciaires** gérant plusieurs dossiers clients via le mode multi-tenant.

Kesh n'est pas conçu pour les grands groupes soumis à l'audit ordinaire (Art. 727 CO, seuils 20/40/250 selon Art. 727 al. 1 ch. 2 CO) ni aux entités cotées en bourse soumises à IFRS / Swiss GAAP RPC obligatoires.

2.3 Architecture technique haute

- **Backend** : Rust 1.96+ (édition 2024) avec le framework HTTP Axum et le client SQL SQLx.
- **Frontend** : SvelteKit 2 avec Svelte 5 et TypeScript, bundler Vite, CSS via Tailwind 4.
- **Base de données** : MariaDB 10.11+ (compatibilité MySQL 8 maintenue, mais MariaDB recommandée pour les optimisations spécifiques utilisées).
- **Déploiement** : Docker Compose, image officielle [gcorbaz/kesh:latest](#) sur Docker Hub.
- **Authentification** : JWT (HS256) avec refresh tokens et rotation, durée d'expiration courte (15 min) compensée par rafraîchissement automatique côté frontend.
- **Multi-tenant** : claim `company_id` dans le JWT et scoping strict sur toutes les requêtes API et toutes les requêtes SQL (cf. Story Epic 7-1 « audit multi-tenant scoping refactor »).

2.4 Licence

Kesh est distribué sous [licence EUPL 1.2](#) (European Union Public Licence). Cette licence est compatible GPL et permet l'usage commercial, la modification et la redistribution sous réserve de conserver la licence et les mentions d'attribution.

3 Prérequis système

3.1 Système d'exploitation

Kesh est officiellement supporté sur :

- **Linux** : Debian 12+, Ubuntu 22.04 LTS+, Fedora 38+, RHEL 9+, Arch Linux (rolling).
- **macOS** : 13 Ventura+ (architecture Intel ou Apple Silicon).

Le déploiement est officiellement supporté sur Linux uniquement. macOS est utilisable pour le développement et l'évaluation, mais non recommandé en production.

Le déploiement sur Windows (avec WSL2) est possible mais non officiellement testé.

3.2 Logiciels requis

- **Docker** ≥ 24.0 (Docker Engine ou Docker Desktop).

- **Docker Compose** ≥ 2.20 (plugin officiel [docker compose](#)).
- Un **reverse proxy HTTPS** en production (Nginx, Caddy, Traefik, HAProxy, ou équivalent).
- Un système de **sauvegarde MariaDB** (mariadb-dump cron, mariabackup, ou solution tierce).
- Optionnel : **Git** pour cloner le dépôt et suivre les mises à jour.

3.3 Ressources matérielles minimales

Ressource	Minimum	Recommandé
CPU	1 vCPU	2–4 vCPU
RAM	1 Go	4 Go
Stockage	5 Go (DB + logs)	50 Go (conservation 10 ans incluse)
Réseau	1 Mbps stable	10 Mbps + IPv4 publique
Disque	SSD recommandé pour DB	SSD obligatoire pour DB

i Note

Le stockage est dominé par l'*audit_log* et les pièces justificatives. Comptez environ **50–200 Mo par exercice** pour une PME standard. Pour une conservation OLICo 10 ans, prévoyez **1–3 Go** en moyenne.

3.4 Ports réseau

Port	Protocole	Usage	Exposition
443	HTTPS	Accès utilisateur via reverse proxy	Publique (Internet)
80	HTTP	API Axum backend (interne)	Localhost uniquement
5173	HTTP	SvelteKit dev server (dev seul)	Localhost uniquement
3306	MySQL/MariaDB	Connexion base de données	Localhost ou réseau privé

! Attention

Ne jamais exposer le port 80 (API Axum) ni le port 3306 (MariaDB) directement sur Internet. Toujours passer par un reverse proxy HTTPS qui termine TLS et fait suivre vers localhost.

3.4.1 Changer le port d'écoute (conflit port 80, ex. Synology DSM Web Station)

Le port `80` par défaut peut entrer en conflit avec un service existant sur l'hôte — typiquement **Synology DSM Web Station** qui occupe également ce port, ou un `nginx` local, un `IIS`, etc. Quatre options d'override existent, selon votre contexte :

1. **Garder le port applicatif 80 mais remapper côté host** (recommandé) — dans `docker-compose.prod, dev.` changer le mapping `"127.0.0.1:80:80"` vers `"127.0.0.1:8080:80"` (ou tout autre `HOST_PORT` libre). L'application reste sur 80 côté container ; URL d'accès : `http://localhost:8080`.
2. **Changer le port applicatif lui-même** — dans `.env`, décommenter et adapter :

```
KESH_PORT=3000
```

puis aligner le mapping `docker-compose.*.yaml` sur `"127.0.0.1:3000:3000"` . URL d'accès : `http://localhost:3000`.

3. **Container sur une IP dédiée (Docker macvlan/ipvlan)** — configurer le container avec sa propre IP via réseau `macvlan` ; le mapping host devient inutile (le container répond directement sur son `IP:80`). Procédure spécifique à votre infrastructure réseau.
4. **Mode `cargo run` natif (hors Docker) sur Linux non-root** — Linux n'autorise pas les utilisateurs non-root à bind un port `<1024` (*security feature*). Dans ce contexte, set **obligatoirement** `KESH_PORT=3000` (ou un autre port `≥ 1024`) dans votre `.env` local. Alternatives possibles mais déconseillées : lancer avec `sudo` , ou ajouter la *capability* via `sudo setcap 'cap_net_bind_serv`

! Astuce

Sur Synology DSM, le port 80 est par défaut redirigé vers DSM Web Station. Sans override, le container Kesh ne pourra pas démarrer («port already in use»). La méthode (1) «remap côté host» est la plus simple pour cohabiter — par exemple `"127.0.0.1:8080:80"` + reverse proxy DSM vers `localhost:8080`.

4 Installation

4.1 Méthode recommandée : Docker Compose

Kesh est livré sous forme d'image Docker. Le déploiement standard utilise Docker Compose.

4.1.1 Étape 1 — Préparer l'environnement

Créer un répertoire dédié pour l'instance Kesh :

```
sudo mkdir -p /opt/kesh
sudo chown $USER:$USER /opt/kesh
cd /opt/kesh
```

4.1.2 Étape 2 — Récupérer le `docker-compose.yml`

Télécharger le fichier de référence depuis le dépôt officiel :

```
curl -fsSL
  https://raw.githubusercontent.com/guycorbaz/kesh/main/docker-compose.yml \
  -o docker-compose.yml
```

4.1.3 Étape 3 — Créer le fichier `.env`

Copier le fichier d'exemple et l'adapter :

```
curl -fsSL
  https://raw.githubusercontent.com/guycorbaz/kesh/main/.env.example \
  -o .env
```

Éditer `.env` et renseigner au minimum les variables suivantes (cf. section 5.1 pour la liste complète) :

```
# Secret JWT - générer avec : openssl rand -hex 32 (minimum 32 octets)
KESH_JWT_SECRET=<secret aleatoire, min. 32 octets, sans "change-me">

# Compte administrateur initial (bootstrap si la base est vide)
KESH_ADMIN_USERNAME=admin
KESH_ADMIN_PASSWORD=<mot de passe fort, min. 12 caracteres>

# Mot de passe DB (conteneur MariaDB)
MARIADB_ROOT_PASSWORD=<mot de passe fort>
MARIADB_PASSWORD=<mot de passe utilisateur applicatif>
MARIADB_DATABASE=kesh
MARIADB_USER=kesh

# URL de connexion DB (service MariaDB nommé "mariadb" dans docker-compose)
DATABASE_URL=mysql://kesh:<MARIADB_PASSWORD>@mariadb:3306/kesh
```

i Note

`KESH_PUBLIC_BASE_URL` (base des liens de réinitialisation par email) n'est requise que si vous activez le recovery par email (`KESH_FEATURE_FORGOT_PASSWORD=true`, cf. §5.1).

X Danger

Ne jamais committer le fichier `.env` dans un dépôt Git. Il contient les secrets de production. Ajoutez-le à `.gitignore`.

4.1.4 Étape 4 — Démarrer les services

```
docker compose up -d
```

Vérifier que les services sont démarrés :

```
docker compose ps
docker compose logs -f kesh-api
```

Au premier démarrage, Kesh exécute automatiquement les migrations de schéma DB. Cela peut prendre 10–30 secondes selon la machine.

4.1.5 Étape 5 — Vérifier l'installation

Tester l'accès à l'API :

```
curl http://localhost/health
# Attendu :
{"status":"ok","db":true,"version":"<version>","forgotPasswordEnabled":false}
```

4.2 Configuration du reverse proxy HTTPS

En production, Kesh **doit** être accessible via HTTPS uniquement. Voici un exemple minimal avec Nginx :

```
# /etc/nginx/sites-available/kesh
server {
    listen 443 ssl http2;
    server_name compta.exemple.ch;

    ssl_certificate
    /etc/letsencrypt/live/compta.exemple.ch/fullchain.pem;
    ssl_certificate_key /etc/letsencrypt/live/compta.exemple.ch/privkey.pem;

    # Strong cipher suite
    ssl_protocols TLSv1.2 TLSv1.3;
    ssl_prefer_server_ciphers on;

    # Headers de securite
    add_header Strict-Transport-Security "max-age=31536000;
    includeSubDomains" always;
```

```
add_header X-Content-Type-Options "nosniff" always;
add_header X-Frame-Options "DENY" always;
add_header Referrer-Policy "strict-origin-when-cross-origin" always;

location / {
    proxy_pass http://localhost;
    proxy_set_header Host $host;
    proxy_set_header X-Real-IP $remote_addr;
    proxy_set_header X-Forwarded-For $proxy_add_x_forwarded_for;
    proxy_set_header X-Forwarded-Proto https;

    # Pour les uploads de pieces comptables et imports CAMT.053
    client_max_body_size 50M;

    # Timeouts adaptes pour les operations longues (exports ZIP)
    proxy_read_timeout 300s;
}

server {
    listen 80;
    server_name compta.exemple.ch;
    return 301 https://$host$request_uri;
}
```

Activer la configuration :

```
sudo ln -s /etc/nginx/sites-available/kesh /etc/nginx/sites-enabled/
sudo nginx -t && sudo systemctl reload nginx
```

4.3 Alternative : déploiement via Caddy

Caddy gère automatiquement les certificats Let's Encrypt et représente une alternative plus simple :

```
# /etc/caddy/Caddyfile
compta.exemple.ch {
    reverse_proxy localhost {
        header_up X-Forwarded-Proto https
    }
    encode gzip
    header {
        Strict-Transport-Security "max-age=31536000; includeSubDomains"
        X-Content-Type-Options "nosniff"
        X-Frame-Options "DENY"
    }
}
```

```
}
```

4.4 Alternative : déploiement via Traefik (avec firewall applicatif)

Traefik est particulièrement adapté quand Kesh est exposé sur Internet : il intègre nativement des middlewares de *firewall applicatif* (rate limiting, IP whitelist, headers de sécurité) et supporte des plugins communautaires plus avancés (CrowdSec pour la détection d'intrusion, ModSecurity-CRS pour des règles WAF type OWASP). La configuration ci-dessous suppose Traefik 3.x déployé en sidecar dans le même Docker Compose que Kesh.

4.4.1 Compose Traefik en sidecar

Ajouter le service Traefik à votre `docker-compose.yml` (ou utiliser un `docker-compose.override.yml` dédié) :

```
services:
  traefik:
    image: traefik:v3.2
    container_name: kesh-traefik
    restart: unless-stopped
    command:
      # Entrypoints HTTP/HTTPS (HTTP redirige vers HTTPS).
      - --entrypoints.web.address=:80
      - --entrypoints.web.http.redirections.entryPoint.to=websecure
      - --entrypoints.web.http.redirections.entryPoint.scheme=https
      - --entrypoints.websecure.address=:443
      # Certificats Let's Encrypt automatiques (challenge HTTP-01).
      - --certificatesresolvers.le.acme.email=admin@example.ch
      - --certificatesresolvers.le.acme.storage=/letsencrypt/acme.json
      - --certificatesresolvers.le.acme.httpchallenge.entrypoint=web
      # Provider Docker - lit les labels sur les autres services.
      - --providers.docker=true
      - --providers.docker.exposedbydefault=false
      # Logs format JSON pour ingestion ultérieure (Loki, ELK, etc.).
      - --accesslog=true
      - --accesslog.format=json
      - --log.level=INFO
    ports:
      - "80:80"
      - "443:443"
    volumes:
      - /var/run/docker.sock:/var/run/docker.sock:ro
      - traefik-letsencrypt:/letsencrypt
    networks:
```

```

- kesh-internal

kesh-api:
  # ... votre config kesh-api existante ...
  # NE PAS publier le port 80 sur l'hôte (Traefik y accède via réseau Docker).
  expose:
    - "80"
  networks:
    - kesh-internal
  labels:
    - traefik.enable=true
    # Router HTTPS + cert Let's Encrypt.
    - traefik.http.routers.kesh.rule=Host(`compta.exemple.ch`)
    - traefik.http.routers.kesh.entrypoints=websecure
    - traefik.http.routers.kesh.tls.certresolver=le
    - traefik.http.services.kesh.loadbalancer.server.port=80
    # Chaîne de middlewares firewall applicatif (cf. ci-dessous).
    -
    traefik.http.routers.kesh.middlewares=kesh-ratelimit@docker,kesh-headers@docker

volumes:
  traefik-letsencrypt:

networks:
  kesh-internal:
    driver: bridge

```

4.4.2 Middlewares firewall applicatif

Définir les middlewares via labels sur le service `kesh-api` (ou dans un `dynamic.yml` dédié) :

```

labels:
  # ... labels routeur ci-dessus ...

  # 1. Rate limiting global - défense contre brute-force et scraping.
  #   Limite moyenne 50 req/s par IP, burst 100. Défense en
  #   profondeur du rate-limit applicatif Kesh (KESH_RATE_LIMIT_*).
  - traefik.http.middlewares.kesh-ratelimit.ratelimit.average=50
  - traefik.http.middlewares.kesh-ratelimit.ratelimit.burst=100
  -
  traefik.http.middlewares.kesh-ratelimit.ratelimit.sourcecriteria.ipstrategy.depth=1

  # 2. Headers de sécurité (durcissement OWASP).
  - traefik.http.middlewares.kesh-headers.headers.stsSeconds=31536000
  -
  traefik.http.middlewares.kesh-headers.headers.stsIncludeSubdomains=true

```

```

- traefik.http.middlewares.kesh-headers.headers.stsPreload=true
- traefik.http.middlewares.kesh-headers.headers.contentTypeNosniff=true
- traefik.http.middlewares.kesh-headers.headers.framedeny=true
-
traefik.http.middlewares.kesh-headers.headers.referrerPolicy=strict-origin-when-cross-or
-
traefik.http.middlewares.kesh-headers.headers.permissionsPolicy=geolocation=(),microphone

# 3. (OPTIONNEL) IP whitelist pour endpoints sensibles - exemple
#   pour bloquer /api/v1/_test/* (qui n'existe qu'en KESH_TEST_MODE
#   mais on défend en profondeur). À adapter à vos IPs admin.
# -
traefik.http.middlewares.kesh-admin-only.ipallowlist.sourcerange=192.168.1.0/24,2001:db8:

```

4.4.3 Plugins WAF avancés (optionnel, recommandé Internet-exposed)

Pour un firewall applicatif complet face à Internet, deux plugins Traefik communautaires sont éprouvés :

CrowdSec — détection d'intrusion collaborative CrowdSec analyse les logs Traefik en temps réel, détecte les scans/scrapes/brute-force, et partage les IPs malveillantes avec une CTI communautaire (équivalent crowd-sourced de *Fail2Ban* + base de réputation IP globale).

```

# Activer le plugin dans la commande Traefik (ajouter dans le `command:`
# ci-dessus) :
-
--experimental.plugins.crowdsec-bouncer.modulename=github.com/maxlerebourg/crowdsec-bouncer
- --experimental.plugins.crowdsec-bouncer.version=v1.3.5

# Puis sur kesh-api, ajouter le middleware :
labels:
-
traefik.http.middlewares.kesh-crowdsec.plugin.crowdsec-bouncer.enabled=true
-
traefik.http.middlewares.kesh-crowdsec.plugin.crowdsec-bouncer.crowdsecApiKey=<API_KEY>
# Puis chaîner dans la liste des middlewares du routeur :
-
traefik.http.routers.kesh.middlewares=kesh-crowdsec@docker,kesh-ratelimit@docker,kesh-headers@docker

```

Installation locale CrowdSec : voir crowdsec.net. Inscription gratuite à la CTI communautaire pour partager les détections.

ModSecurity / OWASP Core Rule Set (CRS) — règles WAF traditionnelles Pour les organisations soumises à audit conformité (RGPD, LPD Suisse, exigences clients), un WAF basé sur OWASP CRS détecte les patterns d'attaque classiques (SQL injection, XSS, path traversal, etc.). Plusieurs intégrations sont disponibles :

- **Coraza** (plugin Traefik officiel WASM) — github.com/jcchavez/coraza-http-wasm. Engine WAF Go natif, performance élevée, règles CRS supportées.
- **ModSecurity v3 + Nginx** en frontal de Traefik — option plus complexe mais plus complète si déjà utilisé en interne.

4.4.4 Considérations sécurité spécifiques

- **Sock Docker exposé** (`/var/run/docker.sock`) : Traefik y accède en lecture seule (`:ro`). En haute exigence sécurité, préférer le `docker-proxy` (image `tecnativa/docker-socket-proxy`) qui filtre les endpoints Docker API accessibles à Traefik.
- **Renouvellement Let's Encrypt** : Traefik gère automatiquement le renouvellement 30 jours avant expiration. Surveiller via `docker logs kesh-traefik | grep acme`.
- **Backup de `acme.json`** : ce fichier contient la clé privée TLS — l'inclure dans votre stratégie de backup (volume `traefik-letsencrypt` ci-dessus).
- **Dashboard Traefik désactivé par défaut** dans cette config (pas de label `api`, pas d'option `--api`). Si vous l'activez en debug, protégez-le impérativement avec une auth + IP whitelist.

4.5 Alternative : déploiement sur Synology DSM

Synology DSM (DiskStation Manager) 7.2+ inclut le paquet *Container Manager* (anciennement *Docker*) qui permet de déployer Kesh sans utiliser le CLI Docker. Cette section couvre le scénario standard d'un déploiement Kesh sur un NAS Synology personnel ou de PME (DS220+, DS920+, DS1522+, DS1821+, ou modèles supérieurs avec ≥ 2 GiB RAM).

4.5.1 Prérequis Synology DSM

- **DSM** ≥ 7.2 (Container Manager n'est pas disponible sur DSM 6.x).
- **Modèle NAS** compatible Docker — vérifier sur la liste officielle Synology : modèles avec processeur Intel/AMD x86_64 (DS220+, DS720+, DS920+, DS1522+, DS1821+, etc.). Les modèles ARM (DS120j, DS220j, DS418, etc.) ne supportent pas Container Manager.
- **RAM** : minimum 2 GiB (4 GiB recommandés pour confort utilisateur multi-tenant avec plusieurs companies actives).
- **Stockage** : au moins 10 GiB libres sur le volume `/volume1` (5 GiB pour l'image Kesh + 1 GiB pour MariaDB initial + 4 GiB marge pour les imports bancaires, exports PDF/ZIP, et croissance données).
- **Paquet Container Manager** installé via Package Center (gratuit, fourni par Synology). Pour DSM 7.2+, c'est l'unique paquet officiel — il remplace l'ancien paquet *Docker*.

4.5.2 Étape 1 — Préparer la structure de répertoires

Via SSH (recommandé) ou File Station (alternative GUI), créer la structure suivante sous `/volume1/docker/kesh/` :

```
# Connexion SSH au NAS (activer SSH dans Panneau de configuration > Terminal
  et SNMP)
ssh admin@<IP-NAS>

# Création des dossiers
sudo mkdir -p /volume1/docker/kesh
cd /volume1/docker/kesh

# Permissions : utilisateur DSM courant + group docker (uid/gid varient
  selon DSM)
# Container Manager rendra les volumes accessibles automatiquement
sudo chown -R $(id -u):$(id -g) /volume1/docker/kesh
```

4.5.3 Étape 2 — Récupérer docker-compose.yml et .env

Télécharger le [docker-compose.yml](#) canonique depuis le dépôt Kesh et créer le fichier `.env` à partir du template (voir section [5.1](#) pour la liste complète) :

```
cd /volume1/docker/kesh
curl -fsSL
  https://raw.githubusercontent.com/guycorbaz/kesh/main/docker-compose.prod.yml
  -o docker-compose.yml
curl -fsSL
  https://raw.githubusercontent.com/guycorbaz/kesh/main/.env.example -o .env

# Générer les secrets obligatoires (DOIVENT remplacer les placeholders dans
  .env)
openssl rand -hex 32 # → KESH_JWT_SECRET
openssl rand -base64 24 # → KESH_ADMIN_PASSWORD
openssl rand -base64 32 # → MARIADB_ROOT_PASSWORD et MARIADB_PASSWORD

# Éditer .env avec vi/nano pour remplacer les <GENERATE_ME: ...> et <EDIT:
  ...>
sudo nano .env
```

! Attention

Sécurité : ne jamais laisser les valeurs par défaut `changeme` ou `change-me-32-bytes-...` dans `.env`. Story 10-1 du hardening Kesh fait fail-fast au boot si ces placeholders restent — c'est intentionnel pour protéger les utilisateurs débutants qui oublient cette étape.

4.5.4 Étape 3 — Importer le projet dans Container Manager

Méthode GUI (recommandée pour débutants)

1. Ouvrir **Container Manager** depuis le menu DSM.
2. Aller dans l'onglet **Projet** (panneau gauche).
3. Cliquer **Créer**.
4. Renseigner :
 - **Nom du projet** : `kesh`
 - **Chemin** : naviguer vers `/volume1/docker/kesh`
 - **Source** : *Utiliser docker-compose.yml existant*
5. Container Manager affiche un preview du compose. Vérifier que les services attendus apparaissent (`kesh-api` , `mariadb` , éventuellement `traefik` si vous l'avez ajouté).
6. Cliquer **Suivant** → **Démarrer le projet maintenant** → **Terminé**.

```
cd /volume1/docker/kesh

# Container Manager DSM expose `docker compose` (plugin v2)
sudo docker compose pull
sudo docker compose up -d

# Vérifier l'état
sudo docker compose ps
sudo docker compose logs -f kesh-api # Ctrl+C pour quitter
```

4.5.5 Étape 4 — Configurer le reverse proxy DSM (Application Portal)

Méthode CLI (équivalente, scriptable) DSM intègre nativement un reverse proxy HTTPS via le *Portail des applications*. Cette option est plus simple que Nginx/Caddy/Traefik pour les petites installations qui n'exposent pas Kesh à Internet (LAN-only).

1. Ouvrir **Panneau de configuration** → **Portail de connexion** → onglet **Avancé** → bouton **Proxy inversé**.
2. Cliquer **Créer**.
3. Renseigner :
 - **Nom de la description** : `Kesh comptabilité`
 - **Source** : Protocole `HTTPS` , Hostname `kesh.local` (ou votre domaine), Port `443`
 - **Destination** : Protocole `HTTP` , Hostname `localhost` , Port `80`
4. Onglet **En-têtes personnalisés** → ajouter :
 - `X-Forwarded-Proto` : `https`
 - `X-Real-IP` : `$remote_addr`

5. Onglet **Avancé** → cocher `HTTP/2` et `HSTS` (Strict-Transport-Security).
6. Cliquer **Enregistrer**.

Certificat HTTPS via DSM Let's Encrypt DSM intègre un client ACME pour Let's Encrypt :

1. **Panneau de configuration** → **Portail de connexion** → onglet **Certificat**.
2. Cliquer **Ajouter** → **Obtenir un certificat de Let's Encrypt**.
3. Renseigner le domaine (`kesh.exemple.ch`), l'email, et un *Subject Alternative Name* optionnel.
4. DSM valide le challenge HTTP-01 ou DNS-01 selon configuration, et installe le certificat automatiquement.
5. Lier le certificat au hostname dans **Paramètres** → sélectionner le service `kesh.exemple.ch` et choisir le nouveau certificat.

i Note

Pour les déploiements exposés sur Internet avec besoin de firewall applicatif (rate limiting, WAF), préférer **Traefik en sidecar** (section 4.4) au Portail DSM. Le Portail couvre les besoins LAN-only ou les déploiements simples derrière un VPN/WireGuard.

4.5.6 Étape 5 — Vérification post-installation

Tester l'instance via le hostname configuré :

```
# Healthcheck (doit retourner JSON avec db:true)
curl -k https://kesh.local/health

# Réponse attendue (Story 10-3) :
# {"status":"ok","db":true,"version":"<version
dynamique>","forgotPasswordEnabled":false}
```

Ouvrir un navigateur sur `https://kesh.local` et se connecter avec le compte admin renseigné dans `.env`. Le wizard d'onboarding démarre automatiquement (création de la première company, choix du plan comptable, configuration des exercices).

4.5.7 Limitations Container Manager DSM

- **Auto-restart** : Container Manager redémarre automatiquement les containers au reboot DSM (équivalent `restart: unless-stopped` dans compose). Pas de configuration supplémentaire requise.
- **Logs** : accessibles via Container Manager GUI (onglet *Container* → sélectionner `kesh-api` → *Détails* → *Journaux*) ou via SSH `docker compose logs -f`.
- **Mises à jour Kesh** : nécessitent un `docker compose pull && docker compose up -d` via

SSH (Container Manager GUI ne propose pas de rebuild automatique sur push d'image). Voir section 8 pour la procédure complète.

- **Backup et restore** : voir section dédiée 7.7 pour les méthodes natives DSM (Hyper Backup, Snapshot Replication).

5 Configuration

5.1 Variables d'environnement complètes

Toute la configuration Kesh passe par des variables d'environnement, conformément à la philosophie [Twelve-Factor App](#). Le fichier `.env` est chargé automatiquement par Docker Compose.

Les tableaux ci-dessous listent **toutes** les variables lues par `kesh-api` (référence : `crates/kesh-api/src/config/main.rs`), par thème. Une valeur hors borne ou invalide déclenche un warning au démarrage et retombe sur le défaut ; les variables « obligatoires » font échouer le démarrage si absentes.

Obligatoires (démarrage refusé si absentes).

Variable	Description
<code>DATABASE_URL</code>	URL de connexion MariaDB : <code>mysql://MARIADB_USER:MARIADB_PASSWORD@MARIADB_DATABASE:3306</code>
<code>KESH_JWT_SECRET</code>	Secret HS256 des JWT. <code>openssl rand -hex 32</code> . Rejeté si absent.

Note — `MARIADB_ROOT_PASSWORD`, `MARIADB_USER`, `MARIADB_PASSWORD`, `MARIADB_DATABASE` ne sont pas lues par `kesh-api` : elles configurent le **conteneur MariaDB** dans `docker-compose`. `DATABASE_URL` doit rester cohérente avec elles.

Serveur & réseau.

Variable	Description	Défaut
<code>KESH_HOST</code>	Adresse d'écoute (0.0.0.0 en Docker, reverse proxy en frontal).	127.0.0.1
<code>KESH_PORT</code>	Port d'écoute (0/invalide → 80).	80
<code>KESH_STATIC_DIR</code>	Répertoire du SPA compilé servi en fallback.	<code>frontend/</code>
<code>KESH_LOCALES_DIR</code>	Répertoire des traductions (FTL).	<code>embarqué</code>
<code>KESH_LANG</code>	Locale de l'instance (<code>fr/de/it/en</code>).	<code>fr</code>

Compte administrateur & onboarding.

Variable	Description
KESH_ADMIN_USERNAME	Admin bootstrap (base vide) ou n Vide → onboarding /setup.
KESH_ADMIN_PASSWORD	Mot de passe admin. Si renseigne refusé si changeme.
KESH_PRODUCTION_RESET	Autorise le reset d'onboarding a (true/1).

Authentification, session & sécurité.

Variable	Description
KESH_JWT_EXPIRY_MINUTES	Durée access 1440].
KESH_REFRESH_TOKEN_MAX_LIFETIME_DAYS	Durée absolu Borne [1, 365].
KESH_REFRESH_INACTIVITY_MINUTES	Inactivité avant (sliding). Borne
KESH_RATE_LIMIT_WINDOW_MINUTES	Fenêtre de com login. Borne [1,
KESH_RATE_LIMIT_MAX_ATTEMPTS	Échecs login pa Borne [1, 100].
KESH_RATE_LIMIT_BLOCK_MINUTES	Durée de bloca [1, 1440].
KESH_PASSWORD_MIN_LENGTH	Longueur min. Borne [8, 128].
KESH_COOKIE_SECURE	Flag Secure (true/false). ment en LAN I

Journalisation.

Variable	Description	Défaut
RUST_LOG	Niveau/directives (trace..error). Baseline sqlx=warn maintenue en debug (anti-fuite SQL).	info
KESH_LOG_FILE_PATH	Fichier de log (rotation). Vide → stdout seul.	§5.2
KESH_LOG_FILE_ROTATION	daily/hourly/never.	daily
KESH_LOG_FILE_MAX_FILES	Fichiers de log conservés.	7
KESH_LOG_FILE_FORMAT	pretty/json.	pretty

Import bancaire, export & sauvegarde.

Variable	Description
KESH_BANK_IMPORT_MAX_MB	Taille max fichier (CAMT.053/CSV), MiB. Borne [1, 10240].
KESH_ADMIN_EXPORT_INMEM_MB	Plafond in-memory de l'export (au-delà : streaming). Borne [1, 10240].
KESH_ADMIN_IMPORT_MAX_MB	Taille max upload .kes. Borne [1, 10240].
KESH_ADMIN_BACKUP_DIR	Répertoire du backup automatique.

Import de factures depuis un dossier (§5.1.1).

Variable	Description
KESH_DOCUMENTS_DIR	Archivage des factures ({sha256}.{extension}).
KESH_INBOX_DIR	Dossier inbox des factures.
KESH_INBOX_MAX_FILE_BYTES	Taille max d'un fichier (en octets). Borne [1, 10240].
KESH_INBOX_MAX_FILES_PER_RUN	Fichiers par run d'import. Borne [1, 10240].
KESH_INBOX_MAX_PDF_PAGES	Pages PDF reçues (anti-DoS). Borne [1, 10240].

E-mails sortants (SMTP) : envoi de factures et recovery de mot de passe. La configuration SMTP sert **deux fonctions indépendantes** (v0.6) : l'**envoi de factures par e-mail** et le **recovery de mot de passe**.

mail s'active dès que les quatre variables `KESH_SMTP_HOST`/`USER`/`PASSWORD`/`FROM` sont renseignées (sans elles, le bouton d'envoi est simplement grisé — jamais de refus de démarrage); le **recovery de mot de passe** exige *en plus* `KESH_FEATURE_FORGOT_PASSWORD=true` et `KESH_PUBLIC_BASE_URL` — et là, si le flag est actif, la config complète est **obligatoire** (dé-

	Variable	Description
marrage refusé sinon).	<code>KESH_FEATURE_FORGOT_PASSWORD</code>	Active le recovery par email (sinon : break-glass via <code>KESH_ADMIN_*</code>).
	<code>KESH_SMTP_HOST</code>	Hôte SMTP (sans port).
	<code>KESH_SMTP_PORT</code>	Port SMTP (587 = STARTTLS). Borne [1, 565535].
	<code>KESH_SMTP_USER</code>	Utilisateur SMTP.
	<code>KESH_SMTP_PASSWORD</code>	Secret SMTP (masqué dans les logs).
	<code>KESH_SMTP_FROM</code>	Adresse expéditrice (email valide).
	<code>KESH_SMTP_TLS</code>	STARTTLS sur la connexion.
	<code>KESH_PUBLIC_BASE_URL</code>	Base publique du lien de reset.

	Variable	Description
Développement / test (jamais en production).	<code>KESH_TEST_MODE</code>	Expose <code>/api/v1/_test/*</code> (reset back obligatoire).

Chemins host des bind mounts (docker-compose, pas lus par l'app). Où les dossiers du conteneur sont montés sur l'hôte, pour un accès depuis le PC (SMB / Synology Drive).

	Variable	Monte sur
Pointez vers un dossier partagé DSM (<code>/volume1/...</code>).	<code>KESH_INBOX_HOST_DIR</code>	<code>/data/inbox</code>
	<code>KESH_DOCUMENTS_HOST_DIR</code>	<code>/data/documents</code>
	<code>KESH_LOG_HOST_DIR</code>	<code>/var/log/kesh</code>

5.1.1 Import de factures depuis un dossier

Kesh peut importer des factures fournisseurs (PDF ou images porteurs d'un Swiss QR Code) déposées dans un dossier, décoder le QR côté serveur et créer des factures « à compléter ». Deux dossiers sont à configurer, montés en volumes persistants (cf. `docker-compose`) :

- `KESH_INBOX_DIR` (défaut `/data/inbox`) — le dossier où déposer les fichiers de factures. Sur un NAS Synology, montez-y un **dossier partagé** accessible via File Station (par ex. un bind mount `./inbox:/data/inbox`) pour pouvoir y glisser vos factures. À l'import réussi, le fichier d'origine est **supprimé** de l'inbox (la copie archivée fait foi) ; les fichiers en échec sont déplacés dans le sous-dossier `failed/`.
- `KESH_DOCUMENTS_DIR` (défaut `/data/documents`) — le dossier d'archivage des justificatifs (copies des fichiers importés, nommées `{sha256}.{ext}`). **Ne jamais** pointer ces deux dossiers vers `/tmp` : leur contenu serait perdu au redémarrage du conteneur.

Note Synology (chemins symboliques). Sur DSM, un dossier partagé comme `/data/inbox` est souvent un lien symbolique vers `/volume1/.../inbox`. Kesh canonicalise automatiquement les chemins au démarrage pour que le contrôle anti-traversal fonctionne — aucune action requise.

Réglage `KESH_INBOX_MAX_PDF_PAGES`. Le décodage des PDF rend chaque page en image (via la bibliothèque native `pdfium`) jusqu'à trouver le QR. Augmentez cette borne si vos factures dépassent 20 pages ; diminuez-la pour limiter la charge sur des PDF volumineux.

Limitations connues.

- La bibliothèque `pdfium` n'est pas isolée : un PDF gravement malformé peut faire planter le processus serveur (le conteneur redémarre alors automatiquement). Limitez l'inbox aux fichiers de confiance.
- L'inbox est un dossier **unique** par instance, non séparé par société. Sur une instance hébergeant plusieurs sociétés, le premier comptable qui déclenche l'import récupère tous les fichiers présents pour sa société. Sans effet pour le déploiement standard « une PME par instance » (cf. issue GitHub #199).

5.1.2 Monitoring

Kesh n'expose pas encore d'endpoint de métriques Prometheus ni d'intégration Sentry en v0.x. Le monitoring se fait via le **healthcheck** `/health` (état DB + version, utilisé par le `healthcheck` Docker) et les **logs** (§5.2).

5.2 Configuration des logs fichier

Depuis la version 0.1.1, Kesh peut écrire ses logs dans un fichier avec rotation native, **en plus** de la sortie standard consultable via `docker logs kesh-api`. C'est utile car la rétention de `docker logs` est purgée à chaque recreation du conteneur, alors qu'un fichier persiste et peut être inclus dans le backup.

En production (`docker-compose.prod.yml`), cette sortie est **activée par défaut** : les logs sont écrits dans `/var/log/kesh/kesh.log` à l'intérieur du conteneur, monté sur le répertoire `./log/` de l'hôte (à côté du `.env` et de la base, donc couvert par le même backup).

Variable	Description	Défaut
KESH_LOG_FILE_PATH	Chemin complet du fichier de log. Vide = logs fichier désactivés (sortie standard uniquement).	<code>/var/log/kesh/kesh.log</code> (en prod)
KESH_LOG_FILE_ROTATION	Stratégie de rotation : <code>daily</code> , <code>hourly</code> ou <code>never</code> .	<code>daily</code>
KESH_LOG_FILE_MAX_FILES	Nombre de fichiers conservés. Ignoré si rotation = <code>never</code> .	<code>7</code>
KESH_LOG_FILE_FORMAT	Format : <code>pretty</code> (lisible) ou <code>json</code> (ingestion outillée).	<code>pretty</code>

! Attention

Le conteneur `kesh-api` s'exécute en tant que `root`, donc le répertoire `./log/` et ses fichiers appartiennent à `root:root` sur l'hôte NAS. Hyper Backup (qui tourne en `root`) les sauvegarde sans problème. Pour consulter les logs avec un compte non-`root`, utilisez `sudo tail -f ./log/kesh.log` ou ajustez les permissions du répertoire.

Pour **désactiver** les logs fichier (sortie standard uniquement), définir `KESH_LOG_FILE_PATH=` (valeur vide) dans le `.env`.

5.3 Configuration MariaDB

5.3.1 Paramètres recommandés

Modifier la configuration MariaDB pour optimiser l'usage Kesh. Créer `/etc/mysql/mariadb.conf.d/99-kesh.cnf`

```
[mariadb]
# Encodage strict pour la conformite Unicode (factures multilingues)
character-set-server = utf8mb4
collation-server     = utf8mb4_unicode_ci

# Niveau d'isolation par default (REPEATABLE READ par default MariaDB,
# Kesh utilise des transactions explicites SERIALIZABLE pour les
# operations critiques comme la numerotation des factures et la
# reconciliation bancaire)
```

```
transaction-isolation = REPEATABLE-READ

# Mode SQL strict pour éviter les coercions silencieuses
sql_mode =
    STRICT_TRANS_TABLES,NO_ENGINE_SUBSTITUTION,ERROR_FOR_DIVISION_BY_ZERO

# InnoDB buffer pool (~ 50% de la RAM disponible)
innodb_buffer_pool_size = 1G
innodb_log_file_size    = 256M
innodb_flush_log_at_trx_commit = 1
innodb_flush_method     = O_DIRECT

# Logs lents pour audit performance
slow_query_log          = 1
slow_query_log_file     = /var/log/mysql/slow.log
long_query_time         = 2

# Binlog pour replication ou point-in-time recovery
log_bin                 = /var/log/mysql/mariadb-bin
binlog_format           = ROW
expire_logs_days        = 14
```

! Astuce

Pour une PME standard (1 société, < 50'000 écritures/an), les paramètres par défaut MariaDB suffisent largement. Cette configuration avancée n'est utile qu'à partir de plusieurs sociétés ou de très gros volumes.

5.3.2 Initialisation manuelle de la base

Si vous ne passez pas par Docker Compose, voici comment initialiser manuellement la DB :

```
mariadb -u root -p <<SQL
CREATE DATABASE kesh CHARACTER SET utf8mb4 COLLATE utf8mb4_unicode_ci;
CREATE USER 'kesh'@'%' IDENTIFIED BY 'mot_de_passe_fort';
GRANT ALL PRIVILEGES ON kesh.* TO 'kesh'@'%';
FLUSH PRIVILEGES;
SQL
```

Au premier démarrage, l'application exécute les migrations SQLx.

5.4 Configuration multi-tenant

Kesh supporte plusieurs sociétés (*companies*) sur une même instance, avec isolation stricte des données.

5.4.1 Concept de *company*

Une *company* représente une entité comptable (PME, association, fondation). Chaque *company* possède :

- Un nom commercial et une raison sociale.
- Un numéro IDE (Identifiant Unique des Entreprises suisse).
- Une langue et timezone par défaut.
- Un plan comptable propre.
- Un ou plusieurs utilisateurs (avec rôles).
- Un ou plusieurs exercices comptables.
- Ses propres factures, contacts, écritures, transactions bancaires, rapports.

5.4.2 Isolation des données

Toutes les requêtes API et toutes les requêtes SQL Kesh sont filtrées par `company_id` (cf. Story Epic 7-1 « audit multi-tenant scoping refactor »). Un utilisateur de la *company* A ne peut en aucun cas accéder aux données de la *company* B, même via une URL forgée (défense en profondeur contre IDOR).

5.4.3 Cas d'usage fiduciaire

Un fiduciaire peut créer une seule instance Kesh avec N *companies*, une par dossier client. L'isolation par `company_id` garantit la confidentialité inter-client. Le fiduciaire peut être membre de toutes les *companies* avec un rôle d'administrateur ; chaque utilisateur PME ne voit que sa propre *company*.

i Note

La création d'une *company* se fait via l'interface utilisateur après connexion d'un administrateur. Voir le *Manuel utilisateur* pour les détails opérationnels.

6 Premier démarrage

6.1 Création du compte administrateur initial (onboarding self-service)

Depuis la version **v0.1.2**, Kesh adopte l'approche *self-service* commune aux applications self-hosted modernes (Jellyfin, Bitwarden, Vaultwarden) : au tout premier démarrage sur une base de données vide, un écran web `/setup` accueille l'administrateur pour créer son compte via un

formulaire — sans édition préalable du fichier `.env`.

Le *bootstrap* crée seulement une **company provisoire** (placeholder) au boot. L'administrateur est ensuite créé via le formulaire `POST /api/v1/setup/admin` (route publique gated par `user_count == 0` → désactivée automatiquement en 410 Gone dès le 1^{er} admin créé).

6.1.1 Procédure (nouveau flow recommandé v0.1.2+)

1. Démarrer la stack (`docker compose up -d`) **sans** renseigner `KESH_ADMIN_*` dans `.env`.
2. Ouvrir <https://compta.exemple.ch> dans un navigateur. L'écran « **Bienvenue dans Kesh** » apparaît automatiquement.
3. Saisir un nom d'utilisateur (ex. `admin`), un mot de passe fort (≥ 12 caractères) et sa confirmation.
4. Cliquer sur « **Créer le compte administrateur** ».
5. Le wizard d'onboarding démarre automatiquement (langue, mode, coordonnées de la société, banque).

! Attention

Sécurité — bloquer l'accès réseau public avant le 1^{er} démarrage. La personne qui touche `/api/v1/setup/admin` en premier devient administrateur. Recommandé : binder loopback `127.0.0.1` (mapping Docker par défaut en prod) ou LAN privé via reverse proxy en attendant la création du compte. Le rate-limit IP (5 tentatives/15 min) limite le brute-force du formulaire.

6.1.2 Procédure alternative — bootstrap déclaratif via `.env`

Pour les déploiements automatisés (CI, Test, scripts de provisioning), il reste possible de créer l'administrateur *déclarativement* via les variables `.env` — équivalent strict du comportement v0.1.0/v0.1.1 :

1. Renseigner `KESH_ADMIN_USERNAME=admin` et `KESH_ADMIN_PASSWORD=<mot-de-passe-fort-12-chars>` dans `.env` *avant* le premier démarrage.
2. Démarrer la stack (`docker compose up -d`). Le boot crée la company stub **et** l'administrateur en une seule passe.
3. Se connecter directement avec ces identifiants — pas d'écran `/setup`.
4. **Retirer les variables `KESH_ADMIN_*` de `.env`** après la première connexion réussie (sinon, chaque redémarrage logge un warning « retirer les vars »).
5. Changer le mot de passe administrateur via l'UI dès que possible.

! Astuce

Le flow self-service `/setup` est préférable pour les déploiements interactifs — il évite la mauvaise pratique consistant à laisser un mot de passe en clair dans `.env`.

6.2 Récupération de mot de passe par email (SMTP)

Depuis la version **v0.2**, Kesh propose un *recovery self-service* : un utilisateur qui a oublié son mot de passe demande un lien de réinitialisation envoyé par email (lien valable **30 minutes**, à usage unique). La fonctionnalité est **désactivée par défaut** (opt-in) : sans configuration SMTP, le seul recours reste le break-glass administrateur (section suivante).

i Note

Depuis la v0.6, la configuration SMTP décrite ici sert **aussi** à l'envoi de factures par email (§6.3) — les deux fonctions sont indépendantes : configurer le SMTP *sans* activer `KESH_FEATURE_FORGOT_PASSWORD` active l'envoi de factures seul.

6.2.1 Variables de configuration

Variable	Description	Défaut
<code>KESH_FEATURE_FORGOT_PASSWORD</code>	Active le recovery par email.	<code>false</code>
<code>KESH_SMTP_HOST</code>	Hôte du serveur SMTP.	—
<code>KESH_SMTP_PORT</code>	Port SMTP.	587
<code>KESH_SMTP_USER</code>	Identifiant SMTP.	—
<code>KESH_SMTP_PASSWORD</code>	Mot de passe SMTP (secret — jamais log-gé).	—
<code>KESH_SMTP_FROM</code>	Adresse expéditrice des emails.	—
<code>KESH_SMTP_TLS</code>	STARTTLS sur la connexion SMTP.	<code>true</code>
<code>KESH_PUBLIC_BASE_URL</code>	URL publique de l'instance, utilisée pour construire le lien de réinitialisation (sans slash final).	—

Fail-fast au démarrage : si `KESH_FEATURE_FORGOT_PASSWORD=true` mais que l'une des variables `KESH_SMTP_HOST`, `KESH_SMTP_USER`, `KESH_SMTP_PASSWORD`, `KESH_SMTP_FROM` ou `KESH_PUBLIC_BASE_URL` est absente ou vide, le serveur **refuse de démarrer** avec un message listant les variables manquantes — plutôt qu'un recovery silencieusement cassé.

! Attention

Laisser `KESH_SMTP_TLS=true` (défaut). Le lien de réinitialisation contient un jeton secret : sans TLS, il transite **en clair** entre Kesh et votre serveur SMTP. Ne désactiver qu'en toute connaissance de cause (relais local de confiance).

6.2.2 Exemples de providers

```
# Gmail (mot de passe d'application requis, pas le mot de passe du compte)
KESH_SMTP_HOST=smtp.gmail.com
KESH_SMTP_PORT=587
KESH_SMTP_USER=mon-compte@gmail.com
KESH_SMTP_PASSWORD=<mot-de-passe-application-16-chars>
KESH_SMTP_FROM=mon-compte@gmail.com

# Postfix local (relais LAN) -- les 4 vars USER/PASSWORD/FROM/PUBLIC_BASE_URL
# restent OBLIGATOIRES (fail-fast), meme si le relais n'exige pas d'auth :
# renseigner les identifiants du relais ou des valeurs convenues avec lui.
KESH_SMTP_HOST=192.168.1.10
KESH_SMTP_PORT=25
KESH_SMTP_TLS=false # uniquement si le relais est de confiance
KESH_SMTP_USER=kesh
KESH_SMTP_PASSWORD=<mot-de-passe-du-relais>
KESH_SMTP_FROM=kesh@mondomaine.ch
KESH_PUBLIC_BASE_URL=https://kesh.mondomaine.ch

# Synology Mail Server (NAS) -- avec un compte dedie du Mail Server.
KESH_SMTP_HOST=nas.local
KESH_SMTP_PORT=587
KESH_SMTP_USER=kesh@nas.local
KESH_SMTP_PASSWORD=<mot-de-passe-du-compte-dedie>
KESH_SMTP_FROM=kesh@nas.local
KESH_PUBLIC_BASE_URL=https://kesh.mondomaine.ch
```

6.2.3 Fonctionnement et garanties

- **Anti-énumération** : la page « Mot de passe oublié ? » répond toujours par le même message générique, que le compte existe ou non. Un attaquant ne peut pas tester l'existence d'un compte.
- **Usage unique + expiration** : le lien expire après 30 minutes et ne fonctionne qu'une fois. Seule une empreinte du jeton est stockée en base.
- **Révocation des sessions** : après réinitialisation, toutes les sessions actives du compte sont déconnectées.
- **Comptes sans email** : un utilisateur sans adresse email n'est pas récupérable par ce flux (le formulaire répond quand même par le message générique). Renseignez les emails via la page *Utilisateurs* — ou utilisez le break-glass (section suivante).
- **Limitation de débit** : 5 requêtes de recovery par IP et par fenêtre de 15 minutes (blocage 30 minutes au-delà). Chaque demande est tracée dans le journal d'audit (`auth.password_reset_requested` / `auth.password_reset_completed`).

6.2.4 Test après configuration (recommandé)

La CI ne peut pas vérifier la délivrabilité réelle des emails. Après avoir activé la fonctionnalité, effectuez un test manuel de bout en bout :

1. Renseignez votre adresse email sur votre compte (page *Utilisateurs*).
2. Déconnectez-vous, cliquez *Mot de passe oublié ?*, saisissez votre nom d'utilisateur ou votre email.
3. Vérifiez la réception de l'email (y compris le dossier indésirables) et suivez le lien pour valider le flux complet.
4. En cas d'échec : les erreurs d'envoi SMTP sont visibles dans les logs serveur (`docker logs kesh-api` , chercher `envoi email échoué`) — elles ne sont jamais exposées côté navigateur (anti-énuation).

Si votre instance envoie vers plusieurs domaines de messagerie (Gmail, Infomaniak, serveur d'entreprise...), testez au moins un destinataire par domaine : la délivrabilité (SPF/DKIM du domaine expéditeur) varie selon le provider.

6.2.5 Limitations connues

- **Horloges synchronisées requises** : la validité du lien (30 min) compare l'horloge de l'application à celle de MariaDB. Un décalage (NTP absent, timezone MariaDB non-UTC) raccourcit ou allonge la fenêtre — un offset d'une heure rendrait les liens inutilisables. En pratique : activez NTP sur l'hôte ; avec le `docker-compose` fourni, les deux conteneurs partagent l'horloge de l'hôte.
- **Reverse proxy et limitation de débit** : la limite « 5 requêtes/15 min » est comptée **par IP source TCP**. Derrière un reverse proxy, tous les clients partagent l'IP du proxy : 5 demandes (même légitimes, d'utilisateurs différents) bloquent le recovery 30 minutes pour toute l'installation. Suivi : [issue #173](#) (support `X-Forwarded-For` opt-in).
- **Blocage = durée du lien** : un utilisateur qui épuise ses 5 essais à mi-parcours doit attendre 30 minutes — et son lien aura expiré entre-temps.
- **Arrêt du serveur pendant l'envoi** : l'email part en tâche de fond après la réponse ; un redémarrage du conteneur à cet instant précis peut perdre l'envoi. La demande reste tracée dans l'audit (`auth.password_reset_requested` sans `auth.password_reset_completed` correspondant), mais l'échec d'envoi lui-même n'apparaît pas dans les logs (le processus s'est arrêté avant de pouvoir l'écrire — un échec SMTP *ordinaire*, lui, est toujours loggé). Il suffit de refaire une demande.

! Astuce

Le recovery par email et le break-glass (section suivante) sont **complémentaires** : le premier couvre les utilisateurs au quotidien sans intervention de l'admin ; le second reste la solution de dernier recours (admin lui-même, SMTP en panne, compte sans email).

6.3 Envoi de factures par e-mail

Depuis la version **v0.6**, Kesh envoie les QR-factures PDF directement par e-mail depuis la fiche facture (bouton *Envoyer par e-mail*, réservé aux rôles Comptable et Administrateur). Le message est pré-rempli dans la **langue du contact** avec une civilité personnalisée, et le destinataire est **verrouillé** sur l'adresse e-mail de la fiche contact (sécurité anti-exfiltration).

6.3.1 Activation

L'envoi s'active dès que les quatre variables `KESH_SMTP_HOST`, `KESH_SMTP_USER`, `KESH_SMTP_PASSWORD` et `KESH_SMTP_FROM` sont renseignées (§6.2 pour les exemples de providers). **Dégradation gracieuse** : sans configuration SMTP, le serveur démarre normalement et le bouton d'envoi est simplement grisé avec une explication — jamais de refus de démarrage pour cette fonction. L'état est exposé par le healthcheck : `GET /health` renvoie `smtpConfigured: true|false`.

6.3.2 Identité d'expédition

- **From** : toujours l'adresse `KESH_SMTP_FROM`, complétée du **nom de votre société** en nom d'affichage (jamais une adresse fournie par l'utilisateur).
- **Reply-To** : l'e-mail de contact de la société s'il est renseigné (*Paramètres* → *Organisation* → *E-mail (adresse de réponse)*), réservé à l'administrateur — les réponses de vos clients arrivent alors dans votre boîte habituelle.

! Attention

Délivrabilité (SPF/DKIM) : utilisez le SMTP de votre fournisseur de messagerie, dont le domaine expéditeur est déjà authentifié (SPF/DKIM) ; n'usurpez pas un domaine tiers. Une adresse `KESH_SMTP_FROM` incohérente avec le domaine du relais finit en spam — ou est rejetée — chez vos clients.

6.3.3 Garanties et limites

- **Anti-abus** : 20 envois par fenêtre de 15 minutes et par utilisateur (puis blocage temporaire 15 minutes).
- **Traçabilité** : chaque envoi est journalisé dans l'audit-trail (`invoice.emailed`, avec destinataire et objet).
- **Renvoi** : autorisé (chaque renvoi écrase la date d'envoi affichée et laisse sa propre trace d'audit).

i Note

« Envoyée » signifie **remise au serveur SMTP**, pas accusé de réception : un rebond ultérieur (adresse invalide, boîte pleine) n'est pas remonté dans Kesh. En cas d'échec de remise immédiat (serveur SMTP injoignable), la facture n'est **pas** marquée envoyée

et un message d'erreur clair est affiché.

6.4 Modèles d'e-mail

Le contenu des e-mails d'envoi de facture se personnalise dans *Paramètres* → *Modèles d'e-mail* (réservé à l'administrateur) : objet et corps, séparément pour chacune des quatre langues (FR/DE/IT/EN — la langue utilisée à l'envoi est celle du contact, sinon celle de l'instance).

- **Variables** : {salutation}, {contactName}, {invoiceNumber}, {amount}, {dueDate}, {companyName} — remplacées automatiquement à l'envoi (montants et dates au format suisse). Une variable inconnue est refusée à l'enregistrement avec un message explicite.
- **Zéro configuration requise** : un modèle par défaut soigné est fourni pour chaque langue — une PME peut envoyer une facture correcte sans jamais ouvrir cette section.
- **Restaurer le défaut** : supprime la personnalisation d'une langue et revient au modèle fourni (action confirmée par une modale).

6.5 Rappels débiteurs (réglages)

Depuis la version **v0.7**, Kesh gère un cycle de **rappels de paiement** (relances débiteurs) multi-niveaux. Les réglages se trouvent dans *Paramètres* → *Rappels débiteurs* (réservé à l'administrateur). L'écran de relance côté utilisateur est décrit dans le manuel utilisateur « Relancer les débiteurs ».

6.5.1 Niveaux de rappel

Chaque **niveau** définit un **délai** (en jours après l'échéance de la facture) et des **frais de rappel** (montant fixe en CHF). Trois niveaux par défaut sont fournis d'origine (*seed* automatique au premier accès) : 1er rappel, 2e rappel, dernier rappel avant poursuite. On peut ajouter, modifier ou supprimer des niveaux, et personnaliser le modèle d'e-mail de chaque niveau (ton en escalade, dans les quatre langues).

- **Délai** : le **niveau 1** devient dû $\text{échéance} + \text{grâce} + \text{délai}(1)$ (compté depuis l'échéance). Les **niveaux suivants** sont comptés depuis la **date d'envoi réelle du rappel précédent** ($\text{dernier rappel} + \text{délai}(N)$), et non depuis l'échéance : si un rappel part en retard, le suivant se décale d'autant. L'échéancier prévisionnel affiché est donc une **projection** valable si chaque rappel est envoyé à temps.
- **Frais** : bornés entre 0 et 10 000.— par niveau.
- **Modèles par niveau** : la page *Modèles d'e-mail* gère plusieurs types (envoi de facture, rappel); pour les rappels, un sélecteur de niveau permet de personnaliser objet et corps. La résolution se fait en cascade : modèle du niveau N → modèle générique → défaut fourni.

6.5.2 Période de grâce

La **période de grâce** (en jours) diffère le premier rappel après l'échéance, pour absorber les délais postaux et bancaires. Un **échancier prévisionnel** affiché en direct montre à quelle date chaque niveau serait proposé (« 1er rappel proposé 15 j après l'échéance, 2e à 25 j... »).

! Attention

Les **frais de rappel** exigent une **base contractuelle** : ils ne sont légalement exigibles que si vos **conditions générales (CGV)** les prévoient et que le client les a acceptées. Kesh affiche un rappel à ce sujet dans l'écran de réglages.

i Note

En v0.7, les frais de rappel sont **affichés mais non comptabilisés** (produit accessoire) et **ne figurent pas sur la QR-facture** : le montant demandé par la QR-facture reste le **total TTC de la facture d'origine**, jamais le total augmenté des frais. Les frais apparaissent dans le courrier de rappel et dans l'historique, à titre de créance accessoire.

6.6 J'ai oublié mon mot de passe administrateur (recovery break-glass)

Depuis la version **v0.1.2**, Kesh permet de réinitialiser le mot de passe administrateur sans accès à la base de données. Le mécanisme *recovery break-glass* réutilise les variables `KESH_ADMIN_*` dans un double-usage : sur une instance déjà configurée (au moins un user existe), renseigner ces variables avec un mot de passe différent du hash actuel déclenche un **reset du password de l'administrateur correspondant au username configuré**.

6.6.1 Procédure step-by-step

1. **Stopper le container** : `docker compose stop kesh-api` (la DB reste accessible pour les autres clients).
2. **Éditer `.env`** : décommenter (ou ajouter) les deux variables :

```
KESH_ADMIN_USERNAME=admin          # le username de votre compte admin
KESH_ADMIN_PASSWORD=<nouveau-mdp-12+> # nouveau mot de passe (>= 12 chars)
```

3. **Redémarrer le container** : `docker compose up -d kesh-api`. Au boot, les logs affichent :

```
WARN bootstrap: Recovery break-glass declenche pour user 'admin'...
ERROR bootstrap: Recovery effectue -- RETIRER LES VARS DE .ENV
```

4. **Se connecter** via l'écran de login avec le nouveau mot de passe. Les sessions actives sur ce compte ont été révoquées par le recovery — les autres onglets/devices devront se reconnecter.

5. Retirer les variables `KESH_ADMIN_*` de `.env` (les recommander ou les supprimer). Tant qu'elles restent en place, un `WARN bootstrap: retirer les vars de .env` apparaît à chaque redémarrage (no-op silencieux côté DB grâce à la détection « hash identique »).
6. (Optionnel) Redémarrer une dernière fois (`docker compose restart kesh-api`) pour confirmer que les warnings bootstrap ont disparu des logs — preuve que les variables `KESH_ADMIN_*` sont bien retirées.

! Attention

Sécurité du fichier `.env`. Tant que `KESH_ADMIN_PASSWORD` est non-vide dans `.env`, toute personne ayant accès à ce fichier peut reset le mot de passe de l'administrateur. Restreindre les permissions : `chmod 600 .env`. Le recovery génère également une entrée `admin_break_glass_reset` dans le journal d'audit (`audit_log` , conservation 10 ans Swiss CO Art. 958f) pour traçabilité.

6.6.2 Matrice de comportement au boot — vue d'ensemble

Selon l'état de la base de données et la présence des variables `KESH_ADMIN_*`, le bootstrap se comporte ainsi :

users	env set ?	match ?	Comportement
vide	non	—	Crée la company stub seule, écran <code>/setup</code> actif
vide	oui	—	Crée stub + admin déclaratif (équivalent v011-2)
existant	non	—	No-op (régime nominal post-bootstrap)
existant	oui	match + hash identique	No-op silencieux, warning « retirer les vars »
existant	oui	match + hash différent	RECOVERY : reset password + révocation tokens + <code>audit_log</code>
existant	oui	no match username	No-op + warning « no user matches »

6.7 Déploiement LAN HTTP-only (sans HTTPS) — v0.1.3+

Contexte : avant v0.1.3, Kesh émettait les cookies de session avec le flag `Secure` en mode production. Le navigateur refuse de stocker ces cookies sur une connexion HTTP non-TLS, rendant l'application inutilisable sur un déploiement LAN strict sans HTTPS (par exemple un NAS Synology privé sur un domaine RFC 8375 `*.home.arpa` derrière un reverse proxy Traefik en HTTP).

Depuis la version **v0.1.3**, la variable d'environnement `KESH_COOKIE_SECURE` permet de désactiver explicitement le flag `Secure` pour ces cas d'usage.

6.7.1 Décision : HTTPS ou HTTP-only ?

Contexte	Recommandation
Prod Internet exposée	HTTPS obligatoire (Let's Encrypt automatique via Traefik / Caddy / Synology DSM). <code>KESH_COOKIE_SECURE</code> reste à la valeur défaut <code>true</code>.
NAS privé LAN avec domaine externe (DDNS, Cloudflare, OVH)	HTTPS recommandé (Let's Encrypt via DNS challenge). <code>KESH_COOKIE_SECURE=true</code>.
NAS privé LAN avec domaine RFC 8375 (*.home.arpa)	2 options : (a) certificat auto-signé avec <code>mkcert</code> + Traefik file provider (browser warning à accepter une fois par poste, cookies Secure marchent) — recommandé. (b) HTTP-only avec <code>KESH_COOKIE_SECURE=false</code>, à n'utiliser que si le LAN est strictement de confiance.
Dev local pur (cargo run sans Docker)	<code>KESH_COOKIE_SECURE=false</code> pour itération rapide. Ne jamais déployer cette configuration en production.

6.7.2 Procédure HTTP-only (`KESH_COOKIE_SECURE=false`)

1. Éditer `.env` :

```
KESH_COOKIE_SECURE=false
```

2. Redémarrer le container : `docker compose restart kesh-api`.

3. Les logs au boot affichent un warning explicite rappelant le compromis sécurité :

```
WARN config: KESH_COOKIE_SECURE=false -- cookies session emis SANS le
flag `Secure`. Acceptable uniquement pour deploiement HTTP-only LAN
strict (e.g. domaine RFC 8375 `*.home.arpa`, NAS prive). NE JAMAIS
activer en prod exposee Internet sans HTTPS -- cookies sniffables
sur tout reseau non-TLS.
```

! Attention

Risque de sécurité avec `KESH_COOKIE_SECURE=false`. Les cookies de session sont émis sans le flag `Secure` et transitent donc en clair sur le réseau HTTP. Un attaquant ayant accès au LAN (`tcpdump`, point d'accès WiFi compromis, switch managé miroir) peut intercepter les cookies et usurper la session administrateur. À n'activer que si le LAN est strictement de confiance et physiquement isolé d'Internet. Ne jamais combiner avec une exposition Internet (port forwarding, reverse-proxy externe, etc.) sans HTTPS.

6.7.3 Valeurs acceptées et fail-fast

`KESH_COOKIE_SECURE` accepte strictement `true` / `1` (par défaut, cookies Secure activés) ou `false` / `0` (cookies sans Secure). Toute autre valeur (`True`, `TRUE`, `yes`, `on`, espaces avant/après, etc.) refuse le démarrage avec un message d'erreur explicite. Ce parsing strict (cohérent avec `KESH_TEST_MODE`) évite l'ambiguïté qui ferait croire qu'un override est actif alors qu'il ne l'est pas.

6.8 Configuration de la company via l'onboarding

Une fois connecté, l'**assistant d'onboarding** (wizard) configure la company provisoire — il n'y a pas d'écran séparé de création de société :

1. **Langue** de l'interface, puis **mode** (guidé ou expert).
2. **Parcours** : données de démonstration (exploration) ou configuration de production.
3. **Type d'organisation** (indépendant, association, PME) et **langue comptable**.
4. **Coordonnées** de l'organisation (raison sociale, adresse, numéro IDE) — ceci renomme la company provisoire et lève la bannière « nom provisoire ».
5. **Compte bancaire** principal (optionnel, configurable plus tard).

Tant que les coordonnées ne sont pas renseignées, une bannière non-bloquante rappelle que

l'entreprise porte un nom provisoire (correctif catch-22 fresh-install, v0.1.1).

6.9 Choix du plan comptable

Kesh inclut plusieurs plans comptables suisses pré-configurés :

Plan	Description
Sterchi PME	Plan comptable standard PME suisse, version Sterchi (la plus répandue). Recommandé pour la majorité des cas.
KMU	Plan KMU (Käfer / Treuhand-Kammer), version simplifiée orientée artisans et indépendants.
Personnalisé CSV	Import d'un plan personnalisé depuis un fichier CSV (format spécifié dans le manuel utilisateur).

! Astuce

Le plan comptable peut être modifié après création (ajout de comptes auxiliaires, sous-comptes, etc.) mais sa structure globale reste stable. Choisir le plan le plus proche de votre activité dès la création évite des migrations ultérieures.

6.10 Configuration des exercices comptables

Chaque company doit définir au moins un exercice comptable (*fiscal year*). Par défaut, l'exercice civil 1^{er} janvier – 31 décembre est créé automatiquement à la création de la company. Pour d'autres exercices (décalés, courts, longs), aller dans *Paramètres* → *Exercices*.

Réouverture d'un exercice clôturé (Admin uniquement). La clôture d'un exercice est un verrou réversible et tracé. La **réouverture** est réservée aux **administrateurs** — plus strict que la clôture, accessible aux comptables — et n'est **pas** disponible via une clé API (opération privilégiée). Elle se fait depuis *Paramètres* → *Exercices comptables*, bouton *Réouvrir*, et exige un **motif obligatoire** conservé dans le journal d'audit (`audit_log`, action `fiscal_year.reopened`, avec l'état avant/après et l'auteur ; conservation 10 ans). Une **garde d'ordre** impose de rouvrir du plus récent vers l'ancien : si un exercice de date de début postérieure est encore clôturé, la réouverture est refusée jusqu'à ce que celui-ci soit rouvert d'abord. Un exercice rouvert redevient éditable et pourra être re-clôturé. Aucune procédure en ligne de commande n'est nécessaire ni disponible pour cette opération.

6.11 Création des utilisateurs et rôles

Kesh utilise un système de contrôle d'accès basé sur les rôles (RBAC) :

Rôle	Permissions
Admin	Toutes les opérations d'une société : gestion des utilisateurs, paramètres de facturation, taux de TVA, plan comptable, exercices, sauvegarde/restauration complète, en plus de toutes les opérations Comptable.
Comptable	Saisie et validation d'écritures, factures (clients et fournisseurs), avoirs, règlements et paiements pain.001, import bancaire, réconciliation, import de factures, rapports et exports.
Consultation	Lecture seule : consultation des écritures, factures, contacts, produits, rapports — aucune mutation.

Kesh définit exactement ces **trois** rôles (`Role::Admin`, `Role::Comptable`, `Role::Consultation`). Chaque utilisateur appartient à **une seule** société (`company_id` porté par le JWT) ; il n'existe pas de rôle « super-admin » cross-société ni de sélecteur de société.

Création d'un utilisateur via l'UI (rôle Administrateur) : *menu* → *Utilisateurs* → *Nouvel utilisateur*.

7 Sauvegarde et restauration

7.1 Importance de la sauvegarde

La sauvegarde régulière de l'instance Kesh est **critique** pour deux raisons :

- 1. Continuité d'activité** : perte de données = arrêt de la comptabilité PME.
- 2. Conformité OLICo Art. 6** (Disponibilité) : « jusqu'à la fin du délai de conservation [10 ans], toute personne autorisée doit pouvoir, en tout temps et dans un délai raisonnable, consulter et vérifier les livres et les pièces comptables ». Une perte de données rend l'instance non-conforme.

7.2 Stratégie recommandée

- **Quotidienne** : `mariadb-dump` complet, conservé 30 jours, stocké en local + offsite (cloud).
- **Hebdomadaire** : snapshot du volume Docker `/var/lib/docker/volumes/kesh_db_data` (gel cohérent via `docker compose stop` puis snapshot, ou via LVM/ZFS).
- **Mensuelle** : export ZIP de souveraineté (Story 9-2b) pour chaque company depuis l'interface utilisateur.

- **Annuelle** : archivage long terme conforme OLICo Art. 9 (support non-modifiable type CD-R, ou hash signé sur support modifiable WORM).

7.3 Script de sauvegarde mariadb-dump

Voici un script bash de référence à exécuter via cron quotidien :

```
#!/bin/bash
# /usr/local/bin/kesh-backup.sh
# Sauvegarde quotidienne de la base Kesh

set -euo pipefail

BACKUP_DIR="/var/backups/kesh"
RETENTION_DAYS=30
TIMESTAMP=$(date +%Y%m%d_%H%M%S)
BACKUP_FILE="${BACKUP_DIR}/kesh_${TIMESTAMP}.sql.gz"

mkdir -p "${BACKUP_DIR}"

# Dump avec gzip et stockage hash SHA-256
docker compose exec -T db \
    mariadb-dump \
    --single-transaction \
    --routines \
    --triggers \
    --events \
    --add-drop-database \
    --databases kesh \
    -u root \
    -p"${MARIADB_ROOT_PASSWORD}" \
    | gzip > "${BACKUP_FILE}"

# Hash SHA-256 pour verification ulterieure (OLICo Art. 9 al. 1.b ch. 1)
sha256sum "${BACKUP_FILE}" > "${BACKUP_FILE}.sha256"

# Conservation 30 jours
find "${BACKUP_DIR}" -name "kesh_*.sql.gz" -mtime +${RETENTION_DAYS} -delete
find "${BACKUP_DIR}" -name "kesh_*.sql.gz.sha256" -mtime +${RETENTION_DAYS} \
    -delete

echo " Sauvegarde terminee : ${BACKUP_FILE}"
```

Crontab d'exemple (sauvegarde à 2h du matin chaque jour) :

```
0 2 * * * /usr/local/bin/kesh-backup.sh >> /var/log/kesh-backup.log 2>&1
```

7.4 Stockage offsite

Synchroniser les sauvegardes vers un stockage distant (S3, Backblaze B2, Wasabi, Hetzner Storage Box, OVH C14, etc.) :

```
# Exemple avec rclone
rclone sync /var/backups/kesh remote:kesh-backups \
  --transfers 4 \
  --checksum \
  --log-file /var/log/kesh-backup-sync.log
```

7.5 Restauration depuis sauvegarde

```
# 1. Verifier l'integrite de la sauvegarde (SHA-256)
cd /var/backups/kesh
sha256sum -c kesh_20260520_020000.sql.gz.sha256

# 2. Arrêter Kesh (pas la DB)
docker compose stop kesh-api

# 3. Restaurer la base
zcat kesh_20260520_020000.sql.gz | docker compose exec -T db \
  mariadb -u root -p"${MARIADB_ROOT_PASSWORD}"

# 4. Redemarrer Kesh
docker compose start kesh-api

# 5. Verifier le fonctionnement
curl http://localhost/health
```

7.6 Test de restauration périodique (OLICo Art. 10 al. 1)

L'article 10 al. 1 OLICo exige que « l'intégrité et la lisibilité des supports d'information sont régulièrement contrôlées ». Cela implique de **tester effectivement la restauration** au moins **annuellement**, sur un environnement de test isolé :

1. Provisionner une instance Kesh de test (machine virtuelle ou container isolé).
2. Restaurer la sauvegarde la plus récente.
3. Vérifier que l'application démarre, que les écritures sont accessibles, qu'un export ZIP de souveraineté peut être généré et que son SHA-256 est identique à celui généré sur l'instance de production avant la sauvegarde.
4. Documenter le test dans un procès-verbal écrit (date, opérateur, résultat, anomalies éven-

tuelles). Conservation 10 ans avec les sauvegardes.

! Astuce

Automatisez ce test annuel via un workflow CI/CD : provisioning Docker éphémère, restauration, exécution de tests E2E Playwright basiques, génération du procès-verbal. Cette automatisation peut être traitée comme une story Epic 10 « Déploiement & Opérations » ou Epic ultérieur.

7.7 Backup natif sur Synology DSM (Hyper Backup + Snapshot Replication)

Pour les installations sur Synology DSM (cf. section 4.5), DSM intègre nativement deux outils de backup éprouvés : **Hyper Backup** (backup incrémental versionné, idéal cloud + LAN) et **Snapshot Replication** (snapshot Btrfs point-in-time, idéal recovery instantané). Ces outils remplacent ou complètent le script `mariadb-dump` CLI ci-dessus selon votre stratégie.

7.7.1 Hyper Backup — backup incrémental + offsite intégré

Hyper Backup est l'outil principal Synology pour les backups versionnés vers stockage local externe (HDD USB, NAS distant), cloud (Synology C2 Backup, S3, Backblaze B2, Wasabi, Google Drive, OneDrive, etc.), ou serveur rsync distant. Il supporte la déduplication, le chiffrement client-side AES-256, et la rotation Smart (équivalent grandfather-father-son).

Configuration Hyper Backup pour Kesh

1. Installer **Hyper Backup** via Package Center (gratuit).
2. Lancer Hyper Backup → + **Tâche de sauvegarde de données** → choisir la destination (ex. *Synology C2 Backup* pour offsite managé, *S3 Storage* pour AWS/Wasabi/Backblaze, *Dossier local* pour HDD USB attaché au NAS).
3. Cocher les dossiers à backup :
 - **Obligatoire** : `/volume1/docker/kesh/` (compose + `.env` + tous les volumes via bind-mount si vous utilisez le pattern Synology recommandé).
 - **Optionnel** : volumes Docker nommés si vous n'utilisez pas le bind-mount (rare sur DSM) — accessibles via `/volume1/@docker/volumes/kesh_*`.
4. Cocher l'application **Container Manager** dans *Applications* pour backup automatique de la configuration des projets.
5. Activer le **chiffrement client-side** (mot de passe différent du `KESH_JWT_SECRET`, stocké séparément offline — la perte de ce mot de passe rend les backups illisibles).
6. Configurer la rotation **Smart Recycle** : recommandé *Conservez toutes les versions des derniers 30 jours + 1 par semaine pour 12 semaines + 1 par mois pour 12 mois*. Convertit OLICo 10 ans en pratique via archivage annuel séparé (cf. *Stockage offsite* ci-dessus).

7. Planifier la fréquence : **quotidienne à 2h du matin** (équivalent du cron du script CLI).
8. Activer les notifications email/push DSM pour alerter d'un échec de backup.

Cohérence transactionnelle MariaDB Hyper Backup copie les fichiers data au niveau système sans coordination avec MariaDB. Pour garantir un dump cohérent (pas de transactions partielles capturées), utiliser un **pre-script Hyper Backup** qui dump MariaDB juste avant le backup, et un post-script qui nettoie après :

```
#!/bin/bash
# /volume1/docker/kesh/pre-backup.sh
# Configure dans Hyper Backup > Parametres > Pre-script

set -euo pipefail
cd /volume1/docker/kesh

# Dump MariaDB juste avant Hyper Backup capture les fichiers
sudo docker compose exec -T mariadb \
    mariadb-dump --single-transaction --routines --triggers --events \
    --add-drop-database --databases kesh \
    -u root -p"${(grep MARIADB_ROOT_PASSWORD .env | cut -d= -f2)}" \
    | gzip > /volume1/docker/kesh/kesh_pre_backup.sql.gz

sha256sum /volume1/docker/kesh/kesh_pre_backup.sql.gz \
    > /volume1/docker/kesh/kesh_pre_backup.sql.gz.sha256
```

Le post-script peut être laissé vide ou utilisé pour supprimer le dump intermédiaire si on préfère minimiser l'espace disque local (au prix de devoir restorer via Hyper Backup pour recovery).

i Note

Pour les charges légères (mono-fiduciaire, < 100 écritures/jour), le simple backup des volumes Docker via Hyper Backup sans pre-script suffit dans 99% des cas — MariaDB redémarre depuis un état semi-cohérent à la restauration, et les éventuelles transactions perdues correspondent à la fraction de seconde du backup. Le pre-script devient utile pour les fiduciaires avec saisie 9-17h continue.

7.7.2 Snapshot Replication — recovery instantané point-in-time

Snapshot Replication fournit des snapshots Btrfs natifs du volume `/volume1/` avec recovery quasi-instantané (< 1 minute) et point-in-time precision (jusqu'à 1 snapshot par 5 minutes). Idéal pour se prémunir contre erreurs humaines récentes (suppression accidentelle d'une écriture, corruption logique) où Hyper Backup serait trop coûteux à restorer (téléchargement cloud + déchiffrement + restore).

Prérequis Snapshot Replication

- Modèle NAS supportant **Btrfs** (DS220+, DS720+, DS920+, DS1522+, DS1821+ — vérifier la liste officielle Synology).
- Volume principal formaté en **Btrfs** (pas EXT4). Si déjà en EXT4, migration nécessaire (sauvegarde complète + recréation du volume + restore — opération longue, planifiée hors période d'activité).
- Paquet **Snapshot Replication** installé via Package Center.

Configuration Snapshot Replication pour Kesh

1. Ouvrir **Snapshot Replication** → onglet **Snapshots**.
2. Sélectionner le dossier partagé `docker` (qui contient `/volume1/docker/kesh`).
3. **Paramètres** → onglet **Snapshot** → activer *Programmer la création de snapshots automatiques*.
4. Fréquence recommandée : **toutes les heures, du lundi au vendredi 6h-22h** (couvre les périodes de saisie active fiduciaire).
5. Rotation : conserver **72 snapshots horaires** (3 jours d'historique) + **14 snapshots quotidiens** + **12 snapshots hebdomadaires**.
6. Activer *Visible aux utilisateurs* si vous voulez permettre aux utilisateurs DSM de naviguer les snapshots via File Station (utile pour récupérer manuellement un fichier supprimé sans intervention admin).

Recovery depuis Snapshot

1. Snapshot Replication → **Snapshots** → sélectionner le dossier `docker`.
2. Choisir le snapshot avec le timestamp pre-incident.
3. **Actions** → **Restaurer** → *Restaurer dans un nouveau dossier* (recommandé, préserve l'état actuel pour comparaison) OU *Écraser le dossier original* (si certain).
4. Après restore : `cd /volume1/docker/kesh && sudo docker compose down && sudo docker compose up -` pour recharger l'instance Kesh sur le state restauré.

7.7.3 Stratégie 3-2-1 sur DSM

Combiner les outils pour atteindre la règle **3-2-1** (3 copies des données, sur 2 supports différents, dont 1 offsite) :

- **Copie 1 (primaire)** : volume Btrfs DSM avec Snapshot Replication actif (recovery rapide erreurs récentes).
- **Copie 2 (locale, support différent)** : Hyper Backup vers HDD USB externe attaché au NAS, rotation Smart Recycle 30 jours + 12 mois.
- **Copie 3 (offsite)** : Hyper Backup vers cloud (Synology C2 Backup pour le confort, ou S3/Backblaze B2 pour le coût optimal), chiffré client-side.
- **Archivage long terme (OLiCo 10 ans)** : 1 dump annuel par year exporté manuellement sur

média WORM (CD-R ou DVD-R inscriptible une fois) ou archivage tape LTO si volume.

! Attention

Test de restauration annuel obligatoire (cf. sous-section précédente OLICo Art. 10 al. 1) : applicable aux backups DSM aussi. Inclure dans le procès-verbal annuel la mention explicite de la méthode utilisée (Hyper Backup, Snapshot Replication) et le temps de recovery mesuré (RTO).

7.8 Export/import d'installation via l'interface Kesh

Depuis la version v0.2, Kesh permet d'**exporter et de réimporter l'intégralité d'une installation** directement depuis l'interface web d'administration, sans accès SSH ni ligne de commande. L'export produit un fichier unique `.keshbackup` (conteneur compressé) contenant **toutes les données d'installation** : l'ensemble des sociétés, les utilisateurs, et les données système. Cette fonction est **réservée au rôle Administrateur** et **inaccessible via une clé API (PAT)** — les opérations d'infrastructure ne transitent jamais par une intégration externe.

i Note

À ne pas confondre avec l'**export global per-société** (menu **Administration** → **Export global**, fichier CSV/ZIP) qui n'extrait les données comptables que d'une seule entreprise pour transmission à un tiers. L'export/import `.keshbackup` décrit ici porte sur l'**installation complète** (toutes entreprises + comptes), pour la migration ou la restauration.

7.8.1 Exporter (sauvegarde complète)

Menu **Administration** → **Sauvegarde complète** (`/admin/backup`) → bouton « **Exporter toute l'installation** ». Le navigateur télécharge un fichier `kesh-installation-AAAA-MM-JJ.keshbackup`. Cette opération est en lecture seule (aucun effet de bord sur les données).

! Attention

Le fichier `.keshbackup` est un **secret** : il contient les **condensés (hash) des mots de passe** de tous les utilisateurs, les **condensés des clés API (PAT)** ainsi que les **jetons de session**. Il n'est **pas chiffré** par défaut. Conservez-le et transmettez-le comme une donnée hautement sensible — chiffrez-le pour tout transit hors de votre infrastructure contrôlée (par ex. `gpg` ou `age`).

7.8.2 Importer (restauration / migration)

Menu **Administration** → **Restaurer / Importer** (`/admin/restore`) → sélection du fichier `.keshbackup` → bouton « **Importer et remplacer l'installation** » → **confirmation forte** dans une fenêtre

modale.

! Attention

Opération destructrice et irréversible. L'import **remplace l'intégralité des données** de l'installation actuelle par celles du fichier. À la fin, vous êtes **déconnecté** et devez vous reconnecter avec les **identifiants de l'instance importée** (les comptes de l'installation précédente n'existent plus). Avant toute suppression, Kesh crée **automatiquement une sauvegarde de l'état courant** côté serveur (répertoire `KESH_ADMIN_BACKUP_DIR`, défaut `/tmp`) en filet de sécurité ; conservez ce répertoire à l'abri et purgez-le selon votre politique.

L'import **refuse** le fichier et préserve l'installation si :

- le fichier est **corrompu** ou n'est pas un `.keshbackup` valide (contrôle d'intégrité SHA-256) ;
- le **schéma** de la sauvegarde est incompatible avec la version de Kesh installée ;
- la sauvegarde **exige une version minimale de Kesh supérieure** à celle de l'installation cible (protection anti-downgrade : ce seuil n'est relevé que par les migrations qui changent le schéma de façon incompatible) — mettez à jour Kesh avant de réimporter.

Reprises de données rejouées à l'import Certaines mises à jour de Kesh ne font pas qu'ajouter des colonnes : elles **renseignent rétroactivement** des données existantes — par exemple les **rôles des comptes** du plan comptable (créances clients, TVA due, résultat de l'exercice...), ou le **compte de produit** des lignes de facture déjà validées.

Une sauvegarde produite **avant** l'une de ces mises à jour ne contient évidemment pas ces données. Or Kesh sait que la reprise a déjà tourné sur l'installation courante, et ne la relancerait donc pas : sans précaution, importer une telle sauvegarde ferait **disparaître ces données définitivement et sans aucun message**.

Kesh **rejoue donc ces reprises à la fin de chaque import**, dans la même opération que la restauration : soit tout réussit, soit rien n'est modifié. Trois propriétés à connaître :

- **Vos données ne sont jamais écrasées.** Si la sauvegarde contenait déjà l'information, elle fait foi : un rôle de compte ou un réglage que vous aviez ajusté à la main est conservé tel quel.
- **L'ordre est celui des mises à jour successives**, afin que le résultat soit identique à celui d'une installation qui aurait suivi le chemin normal des versions.
- **Le détail est tracé** dans le journal d'audit (opération `admin.full_import`) et dans le journal du serveur, qui indiquent quelles reprises ont été rejouées et combien de lignes elles ont touchées.

! Astuce

Si vous avez restauré une sauvegarde **avant** la version qui introduit ce rejeu, il suffit de **relancer le même import** : la reprise s'appliquera cette fois.

Variables d'environnement

- `KESH_ADMIN_IMPORT_MAX_MB` — taille maximale d'un fichier `.keshbackup` importé, en Mio (défaut **512**, bornes [1, 10240]).
- `KESH_ADMIN_EXPORT_INMEM_MB` — plafond d'assemblage en mémoire de l'export; au-delà, l'export est streamé via un fichier temporaire (défaut **50**, bornes [1, 2048]).
- `KESH_ADMIN_BACKUP_DIR` — répertoire de la sauvegarde automatique pré-import (défaut `/tmp`, créé s'il n'existe pas).

7.8.3 Quelle méthode de sauvegarde choisir ?

Kesh propose trois approches complémentaires de sauvegarde. Choisissez selon le besoin :

Méthode	Périmètre	Usage recommandé
Hyper Backup DSM	Volume Docker / MariaDB complet (niveau système, cf. 7.7)	Sauvegarde planifiée automatique quotidienne en production (NAS Synology), avec rotation et offsite.
<code>mariadb-dump</code> CLI	Dump SQL d'une base (niveau base de données)	Sauvegarde ponctuelle technique ou scriptée, pour un opérateur disposant d'un accès SSH.
Export/import <code>.keshbackup</code> (UI)	Installation Kesh complète, portable (niveau applicatif)	Migration entre instances ou restauration self-service sans SSH , déclenchée par un administrateur depuis l'interface.

! Astuce

Ces méthodes ne s'excluent pas : en production, conservez une sauvegarde système **automatique** (Hyper Backup) comme filet quotidien, et utilisez l'export `.keshbackup` pour les **migrations ponctuelles** (changement de serveur, duplication d'environnement)

où la portabilité applicative et l'absence d'accès SSH priment.

8 Mise à jour de Kesh

8.1 Process de release Kesh

Les versions de Kesh sont publiées sur GitHub avec un tag `vX.Y.Z` (versionnage sémantique). À chaque release :

- Une nouvelle image Docker `gcorbaz/kesh:X.Y.Z` et `gcorbaz/kesh:latest` sont poussées sur Docker Hub.
- Un changelog ([CHANGELOG.md](#)) liste les nouveautés, corrections de bugs et changements de compatibilité.
- Les manuels (admin, utilisateur, brochure marketing) sont rebuild en PDF et attachés au release GitHub.
- Les notes de breaking changes sont mises en évidence avec instructions de migration.

8.2 Suivre les notifications de release

- Activer les notifications GitHub : *Watch* le dépôt `guycorbaz/kesh` → *Custom* → *Releases*.
- Souscrire au flux RSS Atom des releases : <https://github.com/guycorbaz/kesh/releases.atom>.

8.3 Procédure de mise à jour standard

1. **Sauvegarder** la base de données et le volume `kesh_db_data` (cf. section précédente).
2. **Lire le changelog** de la nouvelle version pour identifier les breaking changes éventuels et les migrations nécessaires.
3. **Mettre à jour** `docker-compose.yml` si nécessaire (nouvelles env vars, changement d'image).
4. **Tirer la nouvelle image** : `docker compose pull kesh-api`.
5. **Redémarrer** : `docker compose up -d kesh-api`.
6. **Vérifier** les logs : `docker compose logs -f kesh-api` pour s'assurer que les migrations DB se sont bien déroulées.
7. **Tester** l'accès UI et les fonctionnalités critiques (login, saisie d'une écriture, génération d'une facture).

! Attention

Toujours sauvegarder **avant** la mise à jour. Une migration DB peut être irréversible. En cas de problème, la restauration depuis sauvegarde reste votre filet de sécurité.

8.4 Mise à jour majeure (changement de version X)

Une mise à jour majeure (par exemple v0.1 → v1.0) peut comporter des breaking changes. Procédure recommandée :

1. Lire intégralement le changelog et les notes de migration.
2. Provisionner une instance de test en parallèle de la production.
3. Restaurer une copie récente de la base de production sur l'instance de test.
4. Faire la mise à jour sur l'instance de test.
5. Valider toutes les fonctionnalités critiques sur l'instance de test.
6. Sauvegarder la production, puis appliquer la mise à jour.
7. Surveiller les logs pendant 24–48h post-update.

8.5 Rollback en cas d'échec

Si une mise à jour échoue ou révèle un bug bloquant :

```
# 1. Arrêter le service
docker compose stop kesh-api

# 2. Restaurer la version précédente de l'image
docker compose down
# Éditer docker-compose.yml : image: gcorbaz/kesh:0.1.0 (ancien tag)
docker compose up -d

# 3. Si les migrations DB ont été appliquées et sont irréversibles, restaurer
# la sauvegarde DB d'avant la mise à jour (cf. section Restauration).
```

9 Sécurité

9.1 HTTPS obligatoire en production

Kesh **doit** être accessible uniquement via HTTPS en production. Le mode HTTP plain doit être réservé strictement au développement local.

Configurations recommandées du reverse proxy :

- TLS 1.2 minimum, TLS 1.3 préféré.
- Suites de chiffrement modernes uniquement (cf. [Mozilla SSL Config Generator](#)).
- HSTS activé avec `max-age=31536000; includeSubDomains`.
- Certificats Let's Encrypt (renouvellement automatique via Certbot ou Caddy intégré).
- Headers de sécurité : `X-Content-Type-Options: nosniff, X-Frame-Options: DENY, Referrer-Policy: strict-origin-when-cross-origin`.

9.2 Gestion des secrets

- **Jamais committer** `.env` dans Git. Ajouter à `.gitignore`.
- Utiliser un secrets manager (HashiCorp Vault, AWS Secrets Manager, Doppler, ou simplement `systemd-creds` sous Linux) pour les déploiements multi-instances.
- Permissions strictes sur `.env` : `chmod 600 .env` (lecture/écriture propriétaire uniquement).
- Rotation périodique du `KESH_JWT_SECRET` : tous les 6–12 mois en production. Une rotation invalide tous les tokens existants, forçant les utilisateurs à se reconnecter.

9.3 Authentification JWT + refresh tokens

Kesh utilise un modèle JWT avec rotation de refresh tokens :

- L'access token (JWT court, 15 min par défaut) est envoyé en cookie `HttpOnly; Secure; SameSite=Lax`.
- Le refresh token (durée 30 jours par défaut) est stocké en DB (table `refresh_tokens`) avec hash SHA-256 (jamais stocké en clair).
- À chaque refresh, le token précédent est invalidé (rotation), une trace est conservée pour détection d'attaque par replay.
- La déconnexion révoque tous les refresh tokens de la session.

9.4 Clés API (PAT) — accès programmatique

En complément de l'authentification web par cookie, Kesh permet à des **intégrations externes** (IA, scripts, ETL, dashboards BI, ERP) de consommer l'API via des **clés d'accès personnelles** (PAT — *Personal Access Token*). Une clé s'utilise sur les routes `/api/v1/*` existantes, présentée dans l'en-tête `Authorization: Bearer kesh_pat_...`

- **Gestion** : les clés se créent et se révoquent depuis l'interface web, page **Paramètres → Clés API** (`/settings/api-keys`), accessible aux rôles Comptable et Administrateur. La gestion des clés est **impossible via l'API elle-même** (protection anti-auto-propagation : une clé compromise ne peut pas en créer d'autres).
- **Portée** : chaque clé est en *lecture seule* (`read` — méthodes GET/HEAD/OPTIONS) ou

lecture-écriture (`read-write` — toutes les méthodes). La permission effective est l'intersection de la portée de la clé et du rôle de son créateur.

- **Périmètre** : une clé est liée à **une seule entreprise** (*company*) et agit au nom de son créateur (rôle relu en base à chaque requête — désactiver le créateur invalide ses clés immédiatement).
- **Stockage** : seul un condensé SHA-256 de la clé est conservé en base (table `api_keys`) ; le secret en clair n'est affiché qu'une seule fois, à la création.
- **Expiration / révocation** : une clé peut avoir une date d'expiration optionnelle ; la révocation prend effet immédiatement.
- **Audit** : les mutations effectuées via une clé sont tracées dans `audit_log` avec `actor_type = 'api_key'` (et l'identifiant de la clé), conformément à l'OLiCo Art. 9.

! Attention

Moindre privilège. Une clé `read-write` créée par un **Administrateur** hérite des pouvoirs d'Administrateur (gestion d'utilisateurs, réinitialisation de mots de passe, paramètres de facturation) — limitation connue de la v0.2 (suivi GitHub [KF-036 / #167](#)). Ne créez de clés qu'avec le rôle minimal nécessaire, et privilégiez la portée `read` lorsque la lecture suffit. La v0.2 n'applique **pas** de limitation de débit (*rate-limiting*) par clé : utilisez l'expiration et la révocation pour limiter l'exposition.

Le guide d'intégration complet (exemples `curl`, Python, JavaScript, MCP, table des codes d'erreur) est fourni dans le dépôt à `docs/api-external.md`.

9.5 RBAC et permissions

Le contrôle d'accès basé sur les rôles est appliqué **au niveau de chaque endpoint API** via un middleware Tower (Axum). Les 5 rôles standards (cf. section Premier démarrage) sont définis dans le code (pas de rôles custom dynamiques v0.1).

9.6 Audit-trail (`audit_log`)

Toute action métier mutante est enregistrée dans la table `audit_log` :

- Contrainte **insert-only** : aucune route API ne permet de modifier ou supprimer une entrée `audit_log` (défense en profondeur).
- Champs : `user_id`, `company_id`, `timestamp`, `action`, `entity_type`, `entity_id`, `metadata_json`.
- Conservation 10 ans (selon CO Art. 958f al. 1).

9.7 Conformité OLICo Art. 9 — intégrité des supports modifiables

Conformément à l'analyse réglementaire (cf. [_bmad-output/planning-artifacts/research-swiss-co-958f.m](#)), Kesh satisfait l'OLICo Art. 9 al. 1.b par le couple :

- `audit_log` **immutable** insert-only (procédé technique garantissant l'intégrité, condition 1).
- SHA-256 dans `metadata.json` du ZIP d'export de souveraineté (Story 9-2b, condition 1 renforcée).
- Timestamp DB `created_at` pour preuve de moment d'enregistrement (condition 2).
- Documentation des procédures dans ce manuel + journal de bord (conditions 3 et 4).

i Note

La signature électronique qualifiée LSCSE (QES) n'est **pas requise** par l'OLICo pour les exports comptables des PME (interprétation « p. ex. » du législateur). Le verdict (b) « Dette explicite v0.2 » du document de recherche 9-5-4 confirme la conformité v0.1. Une implémentation QES est prévue en v0.2 via Epic 14 (issue GitHub #98).

9.8 Sécurité réseau (firewall)

Configuration firewall minimale (UFW sur Ubuntu/Debian) :

```
sudo ufw default deny incoming
sudo ufw default allow outgoing
sudo ufw allow 22/tcp comment 'SSH'
sudo ufw allow 80/tcp comment 'HTTP (redirect to HTTPS)'
sudo ufw allow 443/tcp comment 'HTTPS'
sudo ufw enable
```

9.9 Mises à jour de sécurité du système hôte

- Appliquer les mises à jour OS automatiquement (`unattended-upgrades` sur Debian/Ubuntu).
- Surveiller les CVE Docker (mise à jour de la version Docker Engine régulière).
- Surveiller les CVE MariaDB (mise à jour de l'image MariaDB lors des releases mineures).
- Souscrire aux annonces de sécurité Kesh (label `security` sur les issues GitHub).

10 Monitoring et logs

10.1 Logs applicatifs

Par défaut, Kesh écrit ses logs sur `stdout` (capturés par Docker) et, en Docker, **aussi** dans un fichier avec rotation (§5.2). Le format du fichier est contrôlé par `KESH_LOG_FILE_FORMAT` (défaut `pretty`; `json` disponible pour l'ingestion Loki/ELK). Consulter le flux `stdout` :

```
docker compose logs -f kesh-api
docker compose logs --tail=100 kesh
docker compose logs --since=1h kesh
```

10.2 Centralisation des logs

En production multi-instances, centraliser via :

- **ELK Stack** : Elasticsearch + Logstash + Kibana.
- **Loki + Grafana** : plus léger, recommandé pour les déploiements modestes.
- **Syslog distant** : configuration via le driver Docker logging `syslog`.

Exemple de driver logging Loki dans `docker-compose.yml` :

```
services:
  kesh:
    image: gcorbaz/kesh:latest
    logging:
      driver: loki
      options:
        loki-url: "https://loki.exemple.ch/loki/api/v1/push"
        loki-retries: "5"
        loki-batch-size: "400"
```

10.3 Supervision (état de santé)

Kesh n'expose pas d'endpoint de métriques Prometheus ni d'intégration Sentry en v0.x. La supervision repose sur deux mécanismes :

- **Healthcheck** `GET /health` — retourne `{"status":"ok","db":true,"version":...,"forgotPassword":...}`. Utilisé par le `healthcheck` Docker (redémarrage automatique si la DB est injoignable). Interrogeable par une sonde externe (Uptime Kuma, cron curl...).
- **Logs** avec rotation (§5.2) — pour l'analyse a posteriori et l'ingestion éventuelle dans un collecteur (Loki, ELK...).

10.4 Alerting recommandé

Alertes Prometheus / AlertManager suggérées :

- Taux d'erreurs HTTP 5xx > 1% sur 5 minutes.
- Latence p95 > 2 secondes sur les requêtes API.
- Connexion DB perdue (échec `kesh_db_queries_total`).
- Disque DB > 80% utilisé.
- Backup quotidien échoué (exit code non-zéro).

11 Conformité légale suisse

11.1 Code des obligations Art. 957a — Tenue de la comptabilité

Kesh satisfait intégralement les exigences de l'Art. 957a CO pour les PME suisses. Les détails de cette conformité sont documentés dans [_bmad-output/planning-artifacts/research-swiss-co-958f.md](#) (Story 9-5-4 « Recherche réglementaire Swiss CO Art. 957a / 958f »).

Synthèse :

- al. 1 : enregistrement intégral, fidèle et systématique → garanti par la saisie partie double et l'`audit_log` immuable.
- al. 2 : principe de régularité → instancié par les patterns techniques Kesh (clarté multilingue, justification, traçabilité).
- al. 3 : pièce comptable papier ou électronique → support électronique autorisé.
- al. 4 : monnaie nationale ou monnaie principale → CHF par défaut, multi-monnaies prévu v0.2.
- al. 5 : langues nationales ou anglais → i18n FR/DE/IT/EN actif.

11.2 Code des obligations Art. 958f — Conservation 10 ans

- al. 1 : conservation 10 ans à compter de la fin de l'exercice → garanti par la persistance MariaDB (sous réserve d'admin DB + backup approprié).
- al. 2 : rapport de gestion imprimé et signé → **responsabilité de la PME utilisatrice**, hors scope logiciel.
- al. 3 : support libre + lien garanti + lisibilité possible → garanti par `audit_log` + SHA-256 +

format CSV/PDF ouverts du ZIP d'export.

11.3 Rétention des rappels débiteurs (dossier de recouvrement)

Depuis la v0.7, chaque rappel envoyé (par e-mail ou enregistré comme rappel papier) est **historisé** dans la table `invoice_reminders` avec une **copie du texte réclamé** et des **frais snapshotés** au moment de l'envoi. Cet historique constitue une **preuve de recouvrement** : en cas de poursuite (LP), il documente les relances effectuées, leurs dates et le destinataire.

- **Conservation** : les rappels suivent la rétention comptable de 10 ans (CO Art. 958f al. 1), portée par la persistance MariaDB (sous réserve d'une administration DB et d'une sauvegarde appropriées).
- **Export et sauvegarde** : les trois tables du dispositif de rappels (`dunning_levels`, `company_dunning_settings`, `invoice_reminders`) figurent dans l'**export de souveraineté** (`exports/global.zip`) et dans la **sauvegarde administrateur** — l'absence des rappels de l'export serait une perte de valeur probatoire.
- **Donnée personnelle (LPD)** : le champ `sent_to` (adresse e-mail du débiteur au moment de l'envoi) est une donnée personnelle conservée pour le respect d'une **obligation légale** (tenue de la comptabilité et preuve de recouvrement, CO Art. 958f), base de licéité admise par la LPD. Elle est conservée 10 ans au même titre que les autres pièces comptables.

! Attention

La **suppression définitive** d'une facture validée par un administrateur (réservée à la correction d'une validation erronée ou à la purge d'essais) **efface aussi l'historique de ses rappels** : le texte réclamé, les frais et le destinataire disparaissent (seule une trace résumée subsiste au journal d'audit). Ne supprimez donc **jamais** une facture qui a fait l'objet de relances si vous devez en conserver la preuve de recouvrement — utilisez plutôt un **avoir**. Une garde applicative empêchant cette suppression est prévue (issue GitHub #260).

11.4 Ordonnance OLICo (RS 221.431)

- Art. 1 : grand livre + journal → implémentés Kesh.
- Art. 3 : intégrité (modification apparente) → garanti par `audit_log` insert-only.
- Art. 9 al. 1.b : supports modifiables (disque dur, SSD) → conditions 1-4 satisfaites (cf. section sécurité plus haut).
- Art. 10 : contrôle et migration → test de restauration annuel obligatoire (cf. section Sauvegarde).

11.5 LSCSE (signature électronique qualifiée)

La signature électronique qualifiée n'est **pas obligatoire** pour la conservation comptable PME selon l'OLiCo Art. 9 (« p. ex. signature électronique »). Une implémentation QES est prévue en v0.2 (Epic 14, issue #98) pour les PME souhaitant un niveau supplémentaire de défense.

11.6 Loi sur la TVA (LTVA)

Kesh comptabilise la TVA suisse : TVA due sur les ventes (générée automatiquement à la validation des factures), impôt préalable sur les achats, décompte par période (solde net dû à l'AFC) et réconciliation du décompte avec le grand livre. La méthode effective (taux réels) est seule supportée.

Configuration des comptes TVA. Trois comptes TVA standard du plan comptable suisse sont nécessaires à la comptabilisation et se configurent depuis *Paramètres* → *Facturation* :

- **TVA due** (p. ex. 2200, passif) — TVA collectée sur les ventes.
- **Impôt préalable** (p. ex. 1171, actif) — TVA récupérable sur les achats. À ne pas confondre avec l'impôt anticipé (1170/Verrechnungssteuer), qui est un compte distinct.
- **Décompte TVA** (p. ex. 2206, passif) — solde net vis-à-vis de l'AFC.

Ces comptes sont ajoutés automatiquement aux plans comptables (PME, indépendant, association) ; les installations existantes sont complétées sans modifier les comptes déjà utilisés. Tant que le compte *TVA due* n'est pas configuré, la validation d'une facture portant de la TVA est refusée (message « configuration requise »). L'usage côté comptable (décompte, réconciliation) est décrit dans le *manuel utilisateur*, section *Décompte TVA*.

Le format de décompte officiel AFC (e-décompte ESTV) et la conformité LTVA Art. 70 (factures électroniques signées) restent hors périmètre à ce stade.

11.7 Documentation à conserver

Conformément à OLiCo Art. 9 al. 1.b ch. 4 (« procédures et modes d'utilisation consignés »), conserver dans votre archive comptable :

- Une copie de ce manuel administrateur (version utilisée).
- Une copie du manuel utilisateur.
- Une copie du document de recherche réglementaire ([research-swiss-co-958f.md](#)).
- Les procès-verbaux de test de restauration annuels.
- Le procès-verbal de migration (cf. metadata.json des ZIP de souveraineté).

! Astuce

Une revue juridique externe (avocat suisse spécialisé en droit commercial / IT) est recommandée mais non bloquante pour une publication commerciale. Coût ordre-de-grandeur : CHF 1'000–3'000 pour une PME. Voir le document de recherche §Verdict pour les détails.

12 Dépannage

12.1 Kesh ne démarre pas

Symptômes Le container `kesh` sort immédiatement après `docker compose up`, **ou** `docker compose ps` montre `kesh` en `Restarting`.

```
docker compose logs kesh | tail -50
```

Causes courantes :

- **DATABASE_URL invalide** : vérifier le format `mysql://user:pass@host:port/db`.
- **DB pas encore prête** : ajouter un `depends_on` avec `condition: service_healthy` dans `docker-compose.yml`.
- **KESH_JWT_SECRET trop court** : doit faire au moins 32 octets (ex. `openssl rand -hex 32` = 64 caractères hexadécimaux).
- **Migrations DB échouées** : voir log détaillé. Solution : restaurer depuis sauvegarde et investiguer.

12.2 Erreurs 401 en cascade côté frontend

Diagnostic

Symptômes Plusieurs appels API consécutifs échouent en `401 Unauthorized` alors que l'utilisateur est censé être authentifié.

Cause Refresh token expiré ou invalidé (cf. KF #54 « E2E test helpers cascade 401 », fermée Epic 9.5).

Solution L'utilisateur doit se reconnecter. Si le problème persiste pour tous les utilisateurs, vérifier l'horloge système (drift NTP).

12.3 Performance lente sur de gros datasets

Symptômes Génération de rapports ou exports ZIP > 30 secondes sur des companies avec > 50'000 écritures.

```
docker compose exec db mariadb -u root -p"${MARIADB_ROOT_PASSWORD}" -e \
    "SELECT COUNT(*) FROM kesh.journal_entries GROUP BY company_id;"
```

Solutions

- Augmenter `innodb_buffer_pool_size` (cf. config MariaDB).
- Vérifier que les index FULLTEXT sont en place (Story 7-4).
- Surveiller `slow.log` et optimiser les requêtes lentes éventuelles.
- Considérer une migration vers MariaDB 11.5+ qui inclut des optimisations supplémentaires.

12.4 Reset du mot de passe administrateur (break-glass)

Si l'administrateur a perdu son mot de passe et qu'il n'y a pas d'autre administrateur, utilisez le mécanisme **break-glass** par variables d'environnement (il n'existe pas d'outil en ligne de commande dédié). Dans le fichier `.env`, renseignez `KESH_ADMIN_USERNAME` avec le nom de l'admin existant et `KESH_ADMIN_PASSWORD` avec le nouveau mot de passe (min. 12 caractères), puis redémarrez :

```
docker compose up -d kesh-api # relit .env au démarrage
```

Au démarrage, si un admin portant ce nom d'utilisateur existe déjà, son mot de passe est ré-initialisé sur la nouvelle valeur. Retirez ensuite `KESH_ADMIN_PASSWORD` du `.env`. Si le recovery par email est activé (`KESH_FEATURE_FORGOT_PASSWORD=true`), l'utilisateur peut aussi passer par le lien « Mot de passe oublié ».

12.5 Données corrompues détectées

Si une vérification d'intégrité (SHA-256 d'un export ZIP ne correspond plus, `audit_log` incohérent, etc.) révèle une corruption :

1. **Arrêter immédiatement** l'instance : `docker compose stop kesh-api`.
2. Conserver une copie de l'état actuel : `tar czf kesh-corrupted-$(date +%F).tar.gz /opt/kesh.`

3. Restaurer depuis la dernière sauvegarde saine (vérifier le SHA-256 de la sauvegarde elle-même avant restauration).
4. Analyser la cause racine : intrusion sécurité ? corruption disque ? bug applicatif ?
5. Documenter l'incident pour l'audit OLICo.

X Danger

Une corruption de données comptables peut avoir des implications légales sévères. Ne pas tenter de « réparer » manuellement les données corrompues — restaurer depuis sauvegarde et investiguer hors production.

13 Maintenance

13.1 Rotation des logs

Configurer logrotate pour éviter que les logs Docker ne saturent le disque :

```
# /etc/docker/daemon.json
{
  "log-driver": "json-file",
  "log-opts": {
    "max-size": "10m",
    "max-file": "5"
  }
}
```

Puis redémarrer Docker : `sudo systemctl restart docker`.

13.2 Maintenance MariaDB

Tâches périodiques recommandées :

Tâche	Description	Fréquence
OPTIMIZE TABLE	Défragmentation des tables InnoDB.	Trimestrielle
ANALYZE TABLE	Mise à jour des statistiques d'optimiseur.	Mensuelle
Vérification cohérence	<code>mariadb-check --all-databases.</code>	Mensuelle
Purge binlog	Suppression des binary logs expirés (auto via <code>expire_logs_days</code>).	Quotidienne (auto)

13.3 Vérification périodique de l'intégrité (OLICo Art. 10)

Conformément à OLICo Art. 10 al. 1, vérifier l'intégrité des supports d'information régulièrement :

```
#!/bin/bash
# /usr/local/bin/kesh-integrity-check.sh
# Verification mensuelle de l'integrite des sauvegardes

BACKUP_DIR="/var/backups/kesh"
LOG_FILE="/var/log/kesh-integrity.log"

echo "  Verification integrite $(date +%F)  " >> "${LOG_FILE}"

cd "${BACKUP_DIR}"
for backup in kesh_*.sql.gz; do
    if sha256sum -c "${backup}.sha256" >> "${LOG_FILE}" 2>&1; then
        echo "  ${backup} OK" >> "${LOG_FILE}"
    else
        echo "  ${backup} INTEGRITE COMPROMISE - ALERTE" >> "${LOG_FILE}"
        # Envoyer une alerte (mail, Slack, PagerDuty, etc.)
    fi
done
```

14 Annexes

14.1 Liste complète des variables d'environnement

Voir section 5.1.

14.2 Opérations en ligne de commande

Kesh ne fournit pas d'outil CLI d'administration dédié : le binaire `kesh-api` est le seul exécutable, et il applique automatiquement les migrations DB au démarrage. Les opérations d'administration passent par l'**interface web** (gestion des utilisateurs, sauvegarde/restauration, export global) ou par les mécanismes documentés ailleurs dans ce manuel :

- **Reset admin** : mécanisme break-glass par `.env` (§12.4).
- **Migrations** : appliquées automatiquement au boot ; vérifiables via les logs de démarrage.
- **Export / import complet** : écran *Administration* → *Sauvegarde complète* / *Restaurer* (format `.keshbackup`).
- **Sauvegarde DB brute** : `mariadb-dump` sur le conteneur MariaDB, ou Hyper Backup au niveau NAS.

14.3 Référence des ports

Service	Port	Notes
Frontend HTTPS (utilisateur)	443	Via reverse proxy
API Axum (interne)	80	Localhost uniquement
MariaDB	3306	Localhost ou réseau privé

14.4 Glossaire

Audit-trail Trace immuable de toutes les actions métier (table `audit_log`).

CAMT.053 Standard ISO 20022 d'extrait de compte bancaire suisse.

Company Entité comptable (PME, association) dans Kesh ; isolation multi-tenant par `company_id`.

Fiscal year Exercice comptable, généralement annuel (1^{er} janvier – 31 décembre par défaut).

IDOR Insecure Direct Object Reference, classe d'attaque évitée via le scoping `company_id`.

Journal entry Écriture comptable en partie double.

OLICo Ordonnance sur la tenue et la conservation des livres de comptes (RS 221.431).

pain.001 Standard ISO 20022 d'ordre de paiement (Customer Credit Transfer Initiation).

QES Qualified Electronic Signature (LSCSE Art. 2 let. e).

QR Bill Standard suisse 2020+ de facture avec QR code (SIX).

RBAC Role-Based Access Control.

Refresh token Token longue durée pour renouveler un access token JWT.

Tenant Synonyme de *company* dans un contexte multi-tenant.

14.5 Liens externes

- Dépôt GitHub Kesh
- Code des obligations RS 220
- Ordonnance OLICo RS 221.431
- Loi LSCSE RS 943.03
- Guide PME comptabilité (SECO)
- QR Bill SIX
- ISO 20022 (CAMT.053, pain.001)

14.6 Support et communauté

- Issues GitHub : <https://github.com/guycorbaz/kesh/issues>
- Discussions : <https://github.com/guycorbaz/kesh/discussions>
- Documentation technique : <https://github.com/guycorbaz/kesh/tree/main/docs>

i Note**À propos de cette version**

Ce document décrit Kesh version **0.8.0** (cible release : v0.8, publié le 2026-07-26). Les manuels Kesh sont mis à jour à chaque release. Pour la dernière version, consultez <https://github.com/guycorbaz/kesh>.

Si vous identifiez une incohérence entre ce manuel et le comportement effectif du logiciel, merci d'ouvrir une issue sur GitHub avec le template `bug_report.yml`.